과정 개요

빌더를 위한 위협 모델링에 오신 것을 환영합니다!

이 과정에서는 위협 모델링에 대한 배경 지식과 이를 수행하는 이유, 그리고 다음을 위한 도구와 기술을 제공합니다.

- 모델링 시스템,
- 위협 식별 및
- 완화책 선택.

본 과정은 시스템 모델 과 그에 따른 **위협 모델을** 구축하는 과정을 안내합니다 . 각 모델의 유용성을 평가해 보세요.

올바른 팀을 구성하세요

위협 모델링은 다양한 팀의 지식과 기술을 필요로 하는 그룹 활동입니다.

귀하의 팀은 다음과 같은 관점을 다루어야 합니다.

자세히 알아보려면 5가지 카테고리를 각각 확장해 보세요.

1. 비즈니스 페르소나

- 위협 모델링 프로세스의 비즈니스 결과를 나타냅니다.
- 고객과 제공되는 가치에 집중합니다.
- 작업 부하의 기능적, 비기능적 요구 사항을 면밀히 이해합니다.
- 위협을 해결하기 위해 제안된 완화책과 비즈니스 요구 사항의 균형을 맞춥니다.

2. 개발자 페르소나

- 작업 부하 기능에 대한 제안된 설계를 이해하고 현재까지 이루어진 설계 결정에 깊이 관여했습니다.
- 디자인 브레인스토밍이나 마커보딩 세션을 진행하고 완화책을 효과적으로 구현하는 방법에 대해 고민합니다.

3. 적대적 페르소나

- 허가받지 않은 사용자의 입장에서 생각해 봅니다.
- 작업 부하를 비판적으로 검토하고 설계 결함을 이용해 특정 목적(예: 무단 데이터 공유)을 달성합니다.
- 위협을 고안하는 데 도움이 되지만 반드시 실행하는 것은 아닙니다.

4. 수비수 페르소나

- 적대적 페르소나가 고안한 위협을 완화하기 위한 보안 제어를 정의합니다.
- 제안된 완화 조치가 지속적인 운영 지원, 모니터링 및 사고 대응 측면에서 관리 가능한지 평가합니다.

5. AppSec SME 페르소나

- 애플리케이션 보안(AppSec) 분야 전문가(SME) 페르소나는 위협 모델링 프로세스와 토론 조정에 매우 익숙합니다.
- 심도 있는 정보기술(IT) 보안 지식과 경험을 갖추고 있습니다.
- 다른 페르소나에게 보안 지침을 제공합니다.
- 토론 조정은 프로세스의 전반적인 목표가 제대로 진행되고 보안과 고객 결과 간의 균형이 유지되도록 하는 데 중요합니다.

팀에 페르소나 매핑

- 이런 페르소나에 잘 어울리는 동료를 알고 계신가요?
- 그렇다면 이 워크시트를 사용하여 페르소나를 팀에 매핑하고 교육에 초대하세요.
- 한 사람이 여러 관점을 가져올 수 있으며, 나열된 인물 중 다수 또는 전부를 대신할 수도 있습니다.
- 의도한 대로 보고 편집하려면 Adobe Acrobat Reader를 사용하여 워크시트를 여세요.

쇼스탁의 4가지 질문 프레임워크

Adam Shostack의 위협 모델링을 위한 4가지 질문 프레임에 답하기 위해 시스템 및 위협 모델링 기술을 적용합니다.

- 우리는 무슨 일을 하고 있나요?
- 무엇이 잘못될 수 있나요?
- 우리는 이에 대해 어떻게 할 것인가?
- 우리가 충분히 잘한 일이었는가?

이 네 가지 질문은 위협 모델링에 대한 체계적인 접근 방식을 제공합니다.

위협 모델링 소개

수업 주제

1. 모델링
2. 위협 모델링이란 무엇인가요?
3. 왜 위협 모델을 사용해야 하나요?
4. 위협 모델을 언제 적용해야 하나요?
5. 위협 모델 작성 방법
6. 추가 자료

모델링

만약 어떤 모델이 100% 정확하다면, 그것은 더 이상 모델이 아닐 것입니다. 그것은 그 자체의 모델이 될 것입니다!



유용성

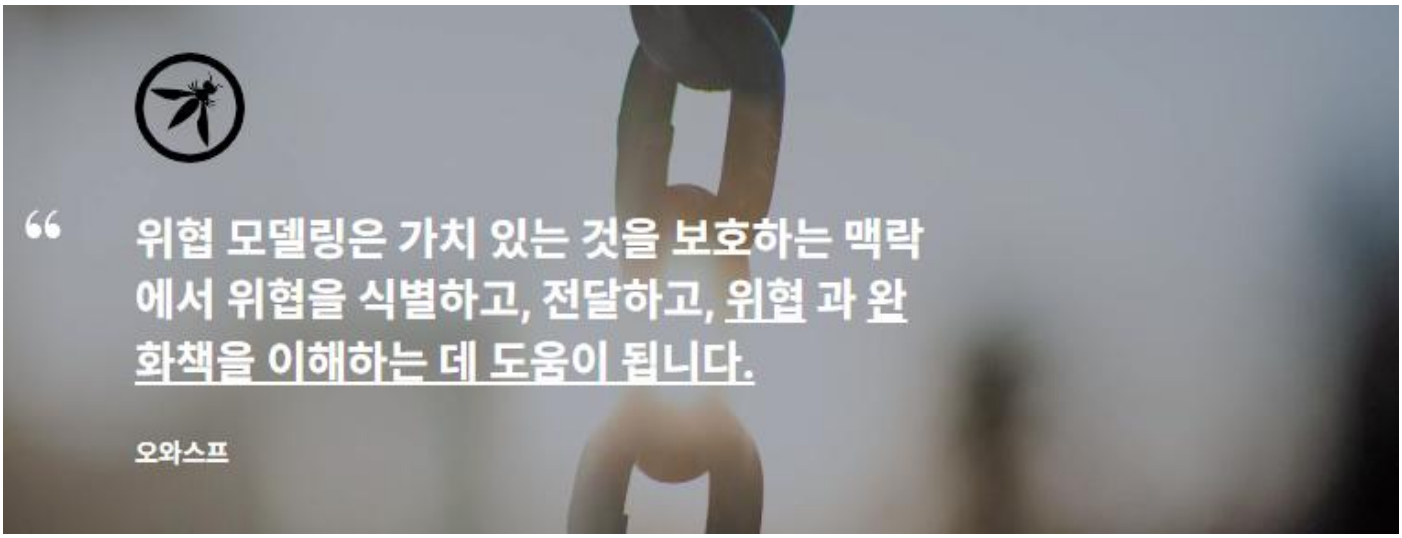
- 모델은 필수적인 단순화입니다.
- 유용한 모델에는 의도한 용도와 관련된 세부 정보가 포함되어 있으면서도 방해 요소는 최소화되어 있습니다.
- 완벽한 모델을 구축하려고 하지 말고, 오직 유용한 정보만 전달되도록 집중하세요.

공통 이해

- 모델링을 통해 모델의 디자인을 시각화할 수 있습니다.
- 이는 귀하와 귀하가 함께 일하는 사람들이 공통의 이해와 참고 문서를 구축하는 데 도움이 됩니다.
- 모든 사람이 자신의 생각을 동일한 시스템에 적용할 수 있습니다.

위협 모델링이란 무엇인가요?

- 논의 중인 시스템에 대한 공통된 이해를 확립합니다.
- 발생할 수 있는 나쁜 일을 파악하고 이에 대한 대처 방법을 알려주는 데 도움이 됩니다.
- 일상생활 속에서 무의식적으로 적용됩니다.



가치 있는 것

시스템의 어떤 측면이 가장 가치 있는지 이해하는 것은 중요합니다. 이를 통해 리소스를 어디에 집중해야 할지 결정하는 데 도움이 됩니다.

왜 위협 모델을 사용해야 하나요?

자세한 내용을 알아보려면 세 섹션을 각각 확장하세요.

보안 문제 식별

좋은 위협 모델은 무엇을 구축하고 있는지, 어떤 문제가 발생할 수 있는지, 그리고 그에 대한 대처 방안은 무엇인지 이해하는 데 도움이 됩니다. 이를 통해 시스템 맥락에서 보안 문제를 해결하기 위한 전략을 수립할 수 있습니다.

이를 통해 재설계 작업, 사후 대응적 보안 작업, 그리고 범위를 벗어난 보안 문제에 소요되는 시간을 줄일 수 있습니다. 보안 사고 발생 가능성도 낮아집니다.

보안 요구 사항 이해

위협 모델링은 귀하의 팀과 귀하가 구축하는 것의 보안에 관심이 있는 모든 사람 사이에 공통된 이해를 확립합니다.

위협 모델은 안전한 제품이나 서비스를 제공하기 위해 무엇이 필요하고 무엇이 필요하지 않은지 정의하고 합의하는 능력을 직접적으로 지원합니다.

생생한 문서이므로 보안 제어를 구현한 것에 대한 팀의 생각과 결정은 물론, 보안 제어를 완화하지 않은 이유까지 담겨 있습니다.

안전하게 빌드하세요

고객을 만족시키려면 제품과 서비스가 안전해야 합니다.

위협 모델링은 초기 설계 단계부터 시작하여 제품이나 서비스를 안전하게 구축하는 데 체계적이고 전략적으로 도움이 됩니다.

위협 모델 작성 방법

위협 모델링은 보호해야 할 가장 중요한 사항을 파악하는 데 도움이 됩니다. 고객 신뢰를 유지하려면 시스템과 데이터의 기밀성, 무결성, 가용성을 보장해야 합니다.

위협 모델링을 위한 Shostack의 4가지 질문 프레임은 시작하기에 좋은 곳입니다 .

질문 1

우리는 무슨 일을 하고 있나요?

이 질문은 여러분이 구축하고 있는 시스템과 보안과 관련된 세부 사항을 이해하고 동의하는 데 도움이 됩니다.

모델/다이어그램을 만드는 것은 이 질문에 답하는 가장 일반적인 방법으로, 무엇을 만들고 있는지 시각화하는 데 도움이 됩니다. 이 과정에서는 데이터 흐름 다이어그램 기법에 중점을 둡니다.

시스템에 대한 가정 사항과 중요한 세부 정보를 기록해 두면 범위에 포함되는 내용을 정의하는 데 도움이 됩니다. 이를 통해 위협 모델에 참여하는 모든 사람이 동일한 주제에 집중할 수 있습니다. 또한 시스템의 이전 버전과 같이 범위에 포함되지 않는 주제로 시간을 낭비하는 것을 방지할 수 있습니다.

예를 들어 , 웹 애플리케이션을 개발하는 경우 브라우저 클라이언트에 대한 운영 체제의 신뢰할 수 있는 부팅 시퀀스를 위협 모델링하는 데 시간을 허비할 필요가 없습니다. 이는 디자인에서 영향을 미칠 수 없습니다.

질문 2

무엇이 잘못될 수 있나요?

위협은 시스템 보안에 원치 않는 영향을 미칠 수 있는 우발적 또는 의도적인 사건입니다. 위협은 보안 위험을 발생시키며, 이는 위협 발생 가능성에 위협의 영향을 곱한 값과 같습니다. 무엇이 잘못될 수 있는지 명확하게 이해하지 못하면 아무런 조치도 취할 수 없습니다.

이 과정의 후반부에서 다루는 요소당 STRIDE는 위협을 식별하는 간단하고 유용한 기법입니다. 다른 방법들도 살펴보는 것이 좋습니다. 더 나은 결과를 얻을 수 있을 때 활용하세요.

질문 3

우리는 이에 대해 어떻게 할 것인가?

무엇이 잘못될 수 있는지 파악했다면, 이를 해결하기 위한 네 가지 전략이 있습니다.

- 위험을 완화하세요 .
- 위험을 피하세요 .
- 위험을 다른 곳으로 전가하세요 .
- 위험을 감수하거나 , 아무런 조치도 취하지 않기로 명확하게 결정합니다.

질문 4

우리가 충분히 잘한 일이었는가?

프로세스 개선을 추진하는 것은 단순히 좋은 성과를 내는 것보다 더 중요합니다. 목표는 시간이 지남에 따라 더 나아지는 것입니다.

Threat Modeling at AWS

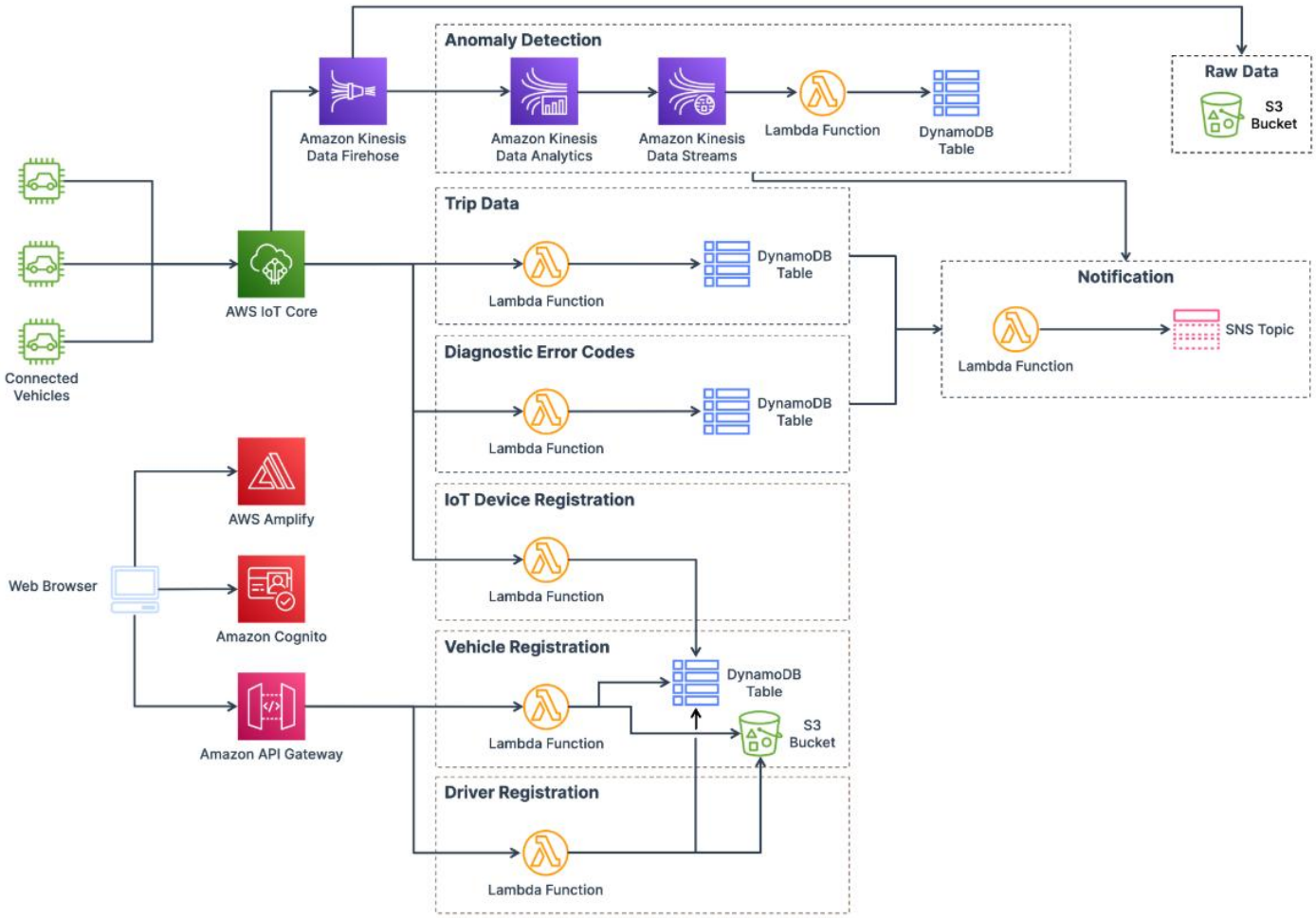
사례 연구

수업 주제

1. AWS 커넥티드 카 솔루션
2. 사용자 스토리
3. 수업 과정
4. 참고문헌

AWS 커넥티드 카 솔루션

이 과정에서는 AWS Connected Vehicle Solution의 핵심 마이크로서비스를 위한 시스템 및 위협 모델을 만드는 방법을 학습합니다.



배경

차량 관리를 위한 AWS 커넥티드 카 솔루션은 이 워크숍의 연습을 기반으로 하는 가상의 시스템입니다.

이 시스템에는 다음을 포함한 여러 기능과 역량이 있습니다.

- 사물인터넷(IoT) 커넥티드카,
- 차량 등록,
- 운전자 등록,
- 진단 오류 코드 캡처 및
- 연결된 차량에서 AWS 솔루션으로 여행 데이터를 전송합니다.

이러한 원격 측정 데이터는 이상 감지를 위한 분석 도구를 통해 전달되며, 이를 통해 차량이 기준 규범 내에서 운행되고 운전자가 교통 규정을 준수하고 있다는 지속적인 보증이 제공됩니다.

많은 현실 세계의 시나리오와 마찬가지로 이는 다소 복잡한 시스템입니다.

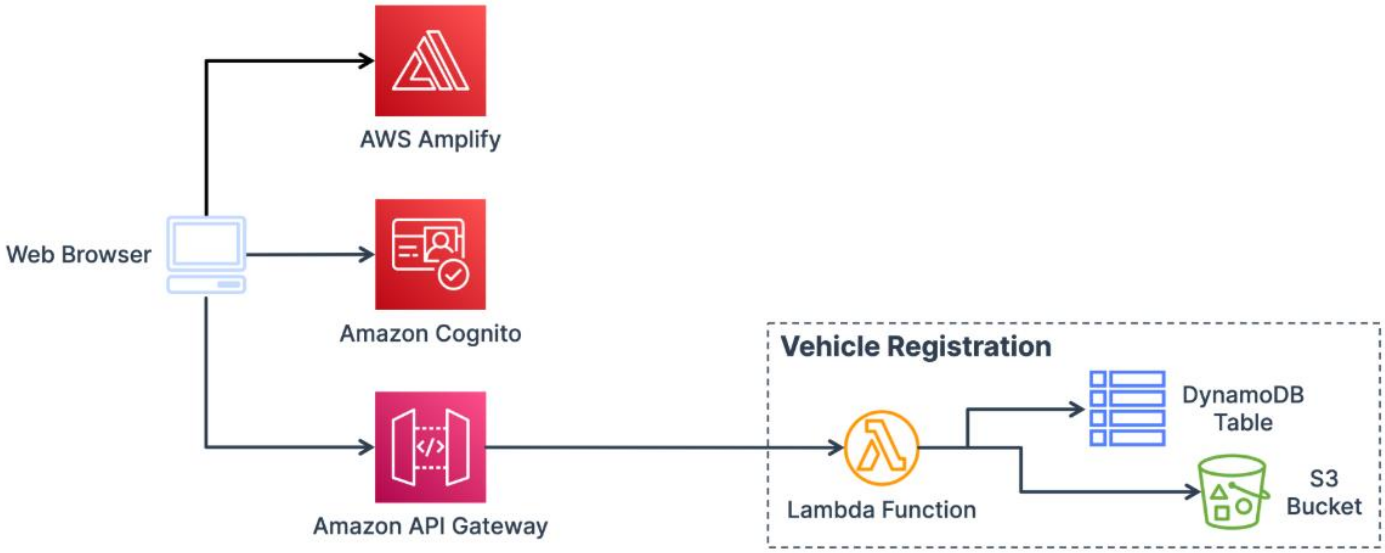
사용자 스토리

AWS Connected Vehicle Solution에 대한 새로운 사용자 스토리가 있습니다.

"차량 관리자로서, 기존 IoT 연결 차량을 등록하여 서비스에 활용하고 싶습니다."

차량 등록 기능

- 이 사용자 스토리는 AWS Connected Vehicle Solution의 차량 등록 기능을 활용합니다.
- 차량 등록 기능은 AWS Amplify에서 호스팅되는 웹 프런트엔드와 Amazon Cognito를 통한 사용자 인증 등, 이미 위협 모델링이 수행되어 가상 시스템에 배포된 기능을 기반으로 구축되었습니다.
- 차량 등록 기능은 향후 작업에서 운전자 등록 및 차량-운전자 연결 기능에 대한 종속성입니다.



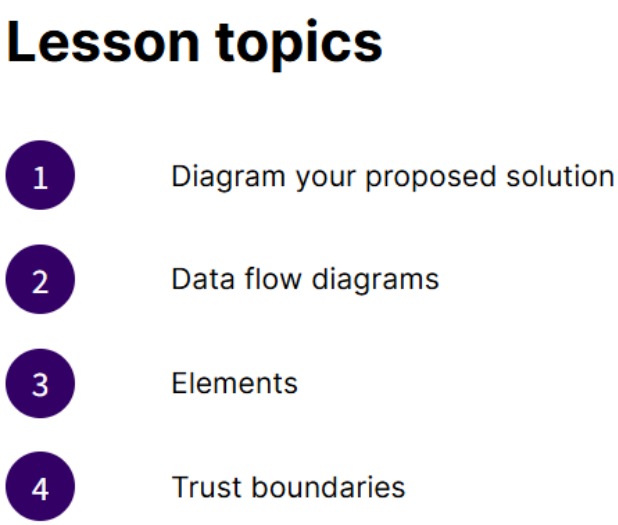
수업 과정

이 워크숍의 연습은 쇼스탁의 4가지 질문 프레임워크로 나뉩니다.

- **우리가 무엇을 하고 있나요?** 차량 등록 기능을 위한 시스템 모델을 만드는 것입니다.
- **무슨 문제가 생길까요?** 차량 등록 기능에 대한 위협을 파악하세요.
- **이에 대해 우리는 어떻게 할 것인가?** 위협의 우선순위를 정하고 완화책을 선택하는 것이다.
- **우리가 충분히 잘 해냈나요?** 과정이 얼마나 유용했는지 평가해 보세요.

1. What Are We Working on?

우리는 무엇을 작업하고 있나요?



제안된 솔루션을 다이어그램으로 표현하세요

- "우리는 무엇을 하고 있는가?"라는 질문에 답하기 위해 제안하는 솔루션을 다이어그램으로 표현해야 합니다.
- 다이어그램은 일반적으로 솔루션의 주요 구성 요소, 데이터 자산, 사용자(인간과 시스템), 신뢰 경계를 보여줍니다.
- 때로는 시스템의 다양한 측면을 파악하기 위해 두 개 이상의 모델을 사용해야 할 수도 있습니다.

샘플 모델

다이어그램을 그리는 데 정해진 방법은 없습니다. 다음과 같이 만들 수 있습니다.

- 데이터 흐름도(권장),
- 공식 시스템 모델,
- 논리적 아키텍처 다이어그램 또는
- 시퀀스 다이어그램.

데이터 흐름도

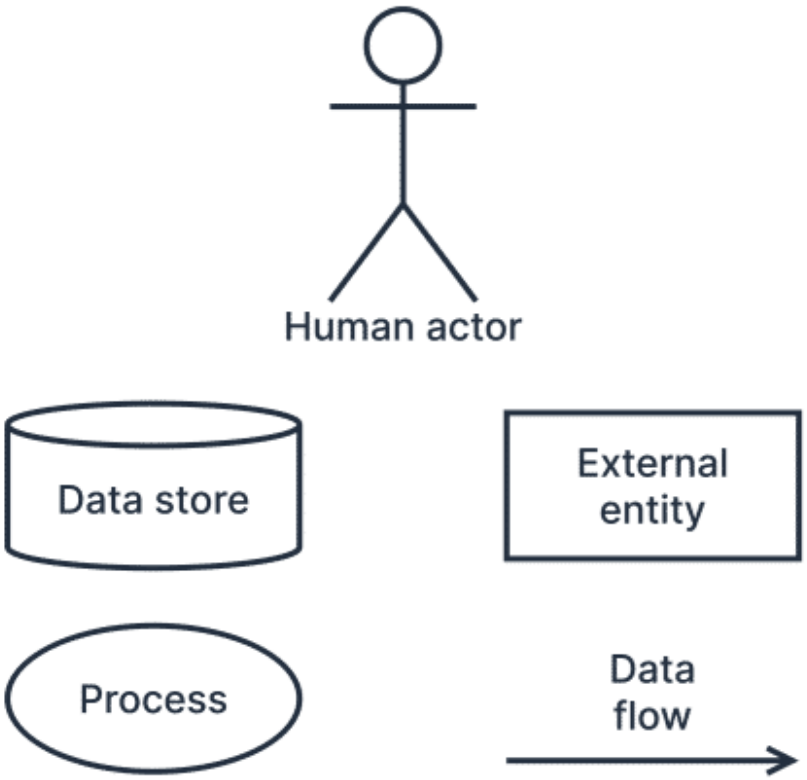
데이터 흐름 다이어그램은 다음을 포함하여 시스템 요소 간의 데이터 교환을 모델링합니다.

- **프로세스.** 데이터를 입력으로 받고, 계산을 수행하고, 데이터를 출력으로 생성하는 요소입니다.
- **데이터 저장소.** 데이터 자산을 보관하는 곳입니다.
- **외부 엔터티.** 사용자가 제어할 수 없지만 시스템과 상호 작용하는 요소입니다. 이러한 엔터티는 종종 시스템 경계 외부에 있습니다.
- **인간 행위자.** 시스템과 상호 작용하는 인간을 모델로 하는 특수한 유형의 개체입니다. 조직 구성원이나 시스템에 접근하는 외부 사람이 포함될 수 있습니다. 인간은 다른 외부 개체와 다르게 행동하고 위협과 완화책이 다를 수 있으므로 이를 구분하는 것이 좋습니다.

데이터 흐름도 특성

- 다양한 종류의 시스템을 모델링합니다.
- 시스템 내에 존재할 수 있는 자산(가치 있는 것)을 식별하고, 어디에 저장되어 있는지 확인합니다.
- 데이터가 시스템을 통해 어떻게 흐르는지, 그리고 해당 데이터를 처리하는 데 문제가 발생할 수 있는 부분을 이해하는 데 사용됩니다.

Elements



제한된 모양의 팔레트

- 요소 유형에 따라 위협 모델링에 대한 보다 일관된 접근 방식을 제공합니다.
- 명확성을 높이고 인지 부하를 줄입니다("하이퍼큐브가 무슨 뜻인지 다시 알려 주세요?").
- AWS 서비스나 리소스에 맞는 아이콘 세트를 찾아 아이콘 세트를 검색할 때 방해 요소를 최소화합니다.
- 시각 장애가 있는 사용자도 접근 가능합니다.

신뢰 경계

신뢰의 영역

시스템은 경계로 구분된 신뢰 영역으로 나눌 수 있습니다. 예를 들어, 외부 엔터티로부터 입력을 받는 프로세스는 기밀 데이터를 보관하는 데이터 저장소와 다른 영역에 있을 가능성이 높습니다.

신뢰 영역 내에서는 모든 요소가 동등하거나 유사한 수준으로 신뢰되는 것으로 간주됩니다. 식별된 각 영역은 서로 다르게 신뢰될 수 있지만, 이것이 신뢰도가 더 높거나 낮음을 의미하는 것은 아닙니다.

보안 제어(완화)는 시스템의 보안 속성을 유지하기 위해 신뢰 경계에 적용하는 것이 가장 효과적인 경우가 많습니다. 신뢰 경계를 그리는 표준 관례는 분리 지점을 나타내는 점선입니다.

데이터 흐름

신뢰 경계를 넘는 데이터 흐름은 문제가 발생할 가능성이 높으므로 위협이 있는지 면밀히 조사해야 합니다.

Exercise: Create a Data Flow Diagram

LESSON 11 OF 27

Lesson topics

1. Overview
2. Vehicle registration feature
3. State your assumptions
4. Draw system elements
5. Draw data flows
6. Draw trust boundaries
7. Check & update assumptions
8. Congratulations

개요

이 연습에서는 차량 등록 기능 요소와 그 요소 간의 데이터 흐름을 나타내는 데이터 흐름 다이어그램을 만드는 데 **30분을 할애합니다 .**

다음 중 가장 편리하다고 생각되는 도구를 사용하세요.

- 큰 종이 한 장, 연필, 지우개;
- 화이트보드;
- 그리기.io위협 모델링을 위한 이러한 라이브러리 사용; 또는
- 플랜트UML일반 텍스트 언어를 사용하여 다이어그램 요소와 흐름을 렌더링합니다.

그룹 활동을 진행하는 경우 모든 사람이 그림을 보고 완전히 참여할 수 있도록 하세요.

시작하기 전에 5분 동안 전체 연습 내용을 읽어보세요. 이는 서비스 모델 다이어그램을 구축하는 데 있어 다양한 수준의 경험이 있는 그룹에서 특히 유용합니다.

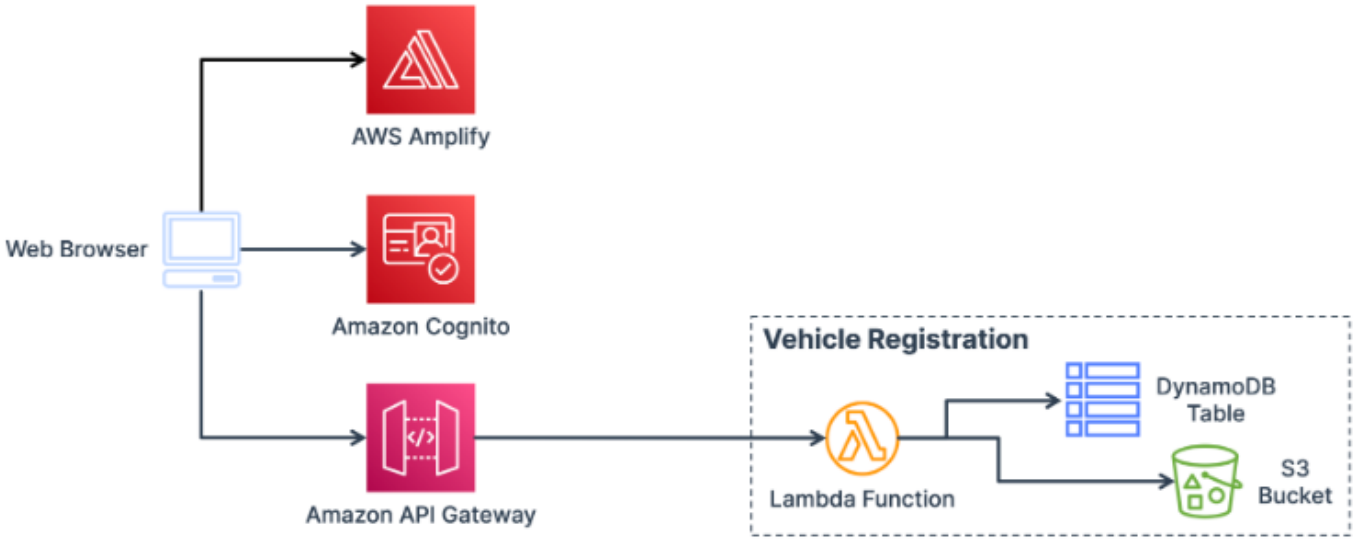
url : https://app.diagrams.net/ (draw.io)

차량 등록 기능

차량 등록 기능은 AWS 커넥티드 카 솔루션의 일부로, 위협 모델에 포함됩니다. 요약하자면, 이 기능은 다음 사용자 스토리를 다루는 것을 목표로 합니다.

"차량 관리자로서, 기존 IoT 연결 차량을 등록하여 서비스에 활용하고 싶습니다."

이 기능은 이미 위협이 모델링되어 배포된 기능, 즉 AWS Amplify에서 호스팅되는 웹 프런트엔드와 Amazon Cognito를 통한 사용자 인증을 기반으로 구축되었습니다.



아키텍처에 포함됨

- 웹 페이지(HTML, JavaScript 및 CSS)를 렌더링하는 데 필요한 정적 자산에 대한 기존 AWS Amplify 배포
- 사용자 풀 인증을 위한 기존 Amazon Cognito 통합.

API 지원

차량 등록 백엔드는 다음 API를 지원합니다.

차량 목록

사용 가능한 모든 IoT 연결 차량에 대한 정보를 반환합니다.

차량 등록

기존 IoT 연결 차량을 등록하여 운행을 시작합니다. 등록 정보에는 등록 번호, 만료일, PDF 형식의 차량 등록 정보가 포함됩니다.

차량 등록 취소

기존에 등록된 IoT 연결 차량을 운행 중단하기 위해 등록을 취소합니다. 등록 취소 시 등록 번호와 만료일이 삭제되고 PDF 파일에서 차량 등록 정보가 삭제됩니다.

차량 설명

사전 서명된 URL을 포함하여 특정 IoT 연결 차량에 대한 정보를 반환합니다.차량 등록을 PDF로 받으세요.

당신의 가정을 말하세요

시작하기 전에 차량 등록 기능이 어떻게 작동하는지에 대한 몇 가지 가정이 있을 수 있습니다.

설계 고려 사항, 위협 및 완화 조치에 대해 가정을 세울 수 있습니다. 이를 통해 노력을 집중하고 관련성이 없는 설계 고려 사항, 범위를 벗어난 위협, 또는 통제할 수 없는 완화 조치에 시간을 낭비하지 않도록 할 수 있습니다. 나중에 가정이 무효화되면 언제든지 위협 모델의 해당 부분을 다시 검토할 수 있습니다.

표로 정리할 수 있습니다. 예를 들면 다음과 같습니다.

상표	설명
WWWO-Assume-1	REST 기반 API는 AWS Lambda와 Amazon API Gateway에서 제공됩니다.
WWWO-Assume-2	모든 사용자가 모든 작업을 수행할 수 있습니다.
WWWO-Assume-3	GUID는 무작위적이고 비순차적입니다.
...	...

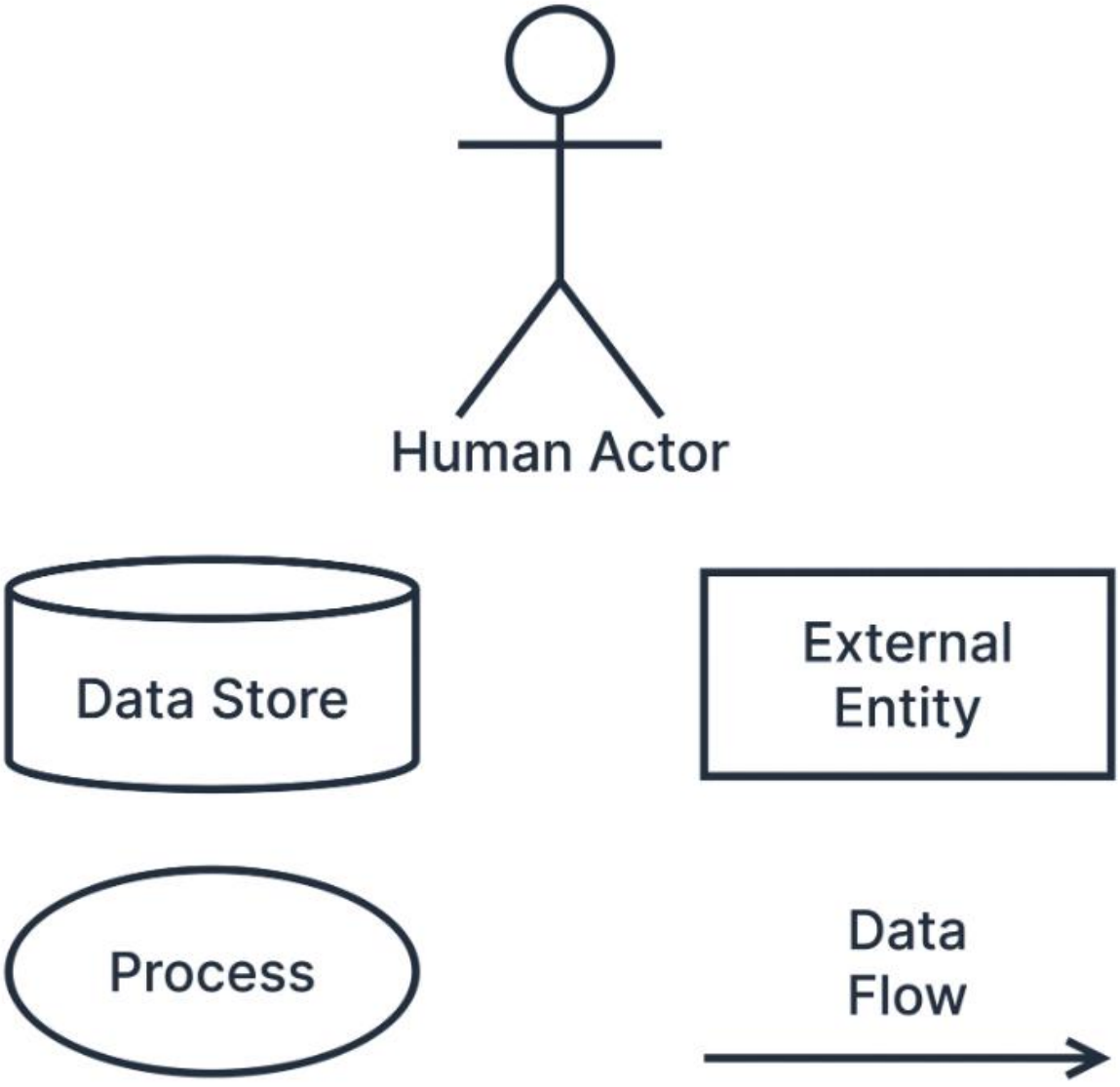
시스템 요소 그리기

시스템 설명을 토대로 차량 등록 기능을 구성하는 각 요소를 **5분 동안 그려보세요 .**

GUID와 같은 데이터 자체가 아닌, 데이터 소스나 저장소(예: Amazon DynamoDB 또는 Amazon S3) 측면에서 요소를 생각해 보세요.

각 요소에 가장 적합한 모양을 사용하여 다이어그램을 그리고 라벨을 붙이세요.

Elements



데이터 흐름 그리기

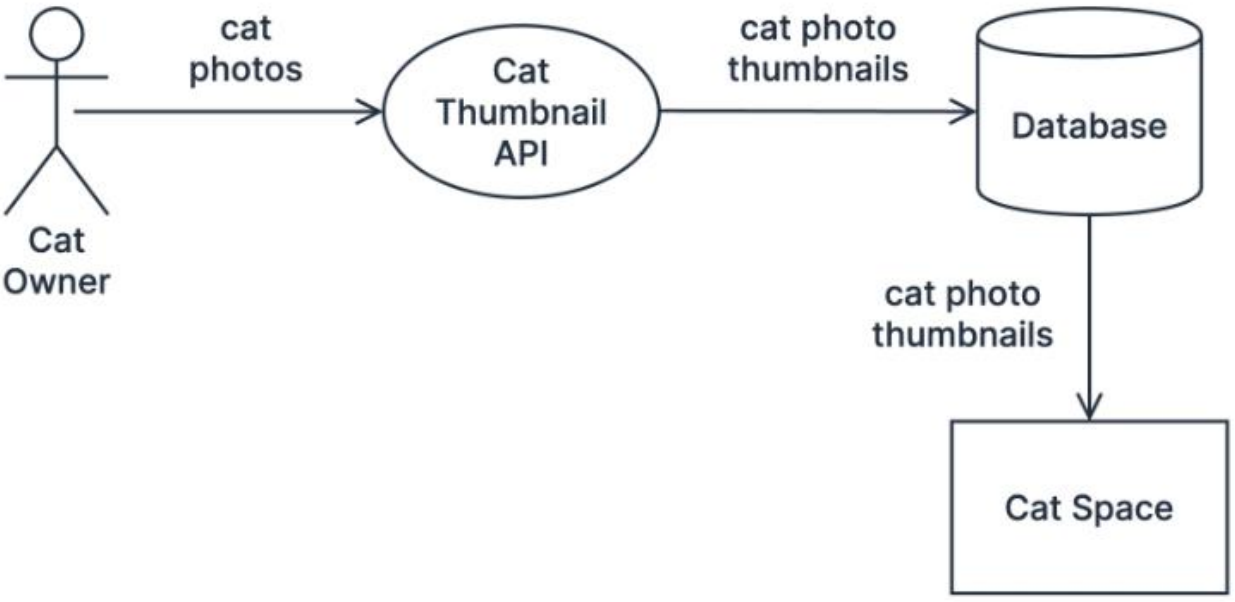
차량 등록 기능을 통해 데이터가 어떻게 흐르는지 보여주기 위해 요소 사이에 화살표를 **5분 동안 그려보세요.**

화살표는 데이터 흐름의 방향을 나타내야 합니다.

복잡계 모델

- 위협을 식별하는 데 도움이 되도록, 보다 복잡한 시스템 모델에서는 각 API에 대해 별도의 데이터 흐름 다이어그램을 사용할 수 있습니다.
- 이 연습에서는 단순화를 위해 단일 데이터 흐름 다이어그램을 사용하여 4개의 차량 등록 기능 API를 모두 모델링합니다.

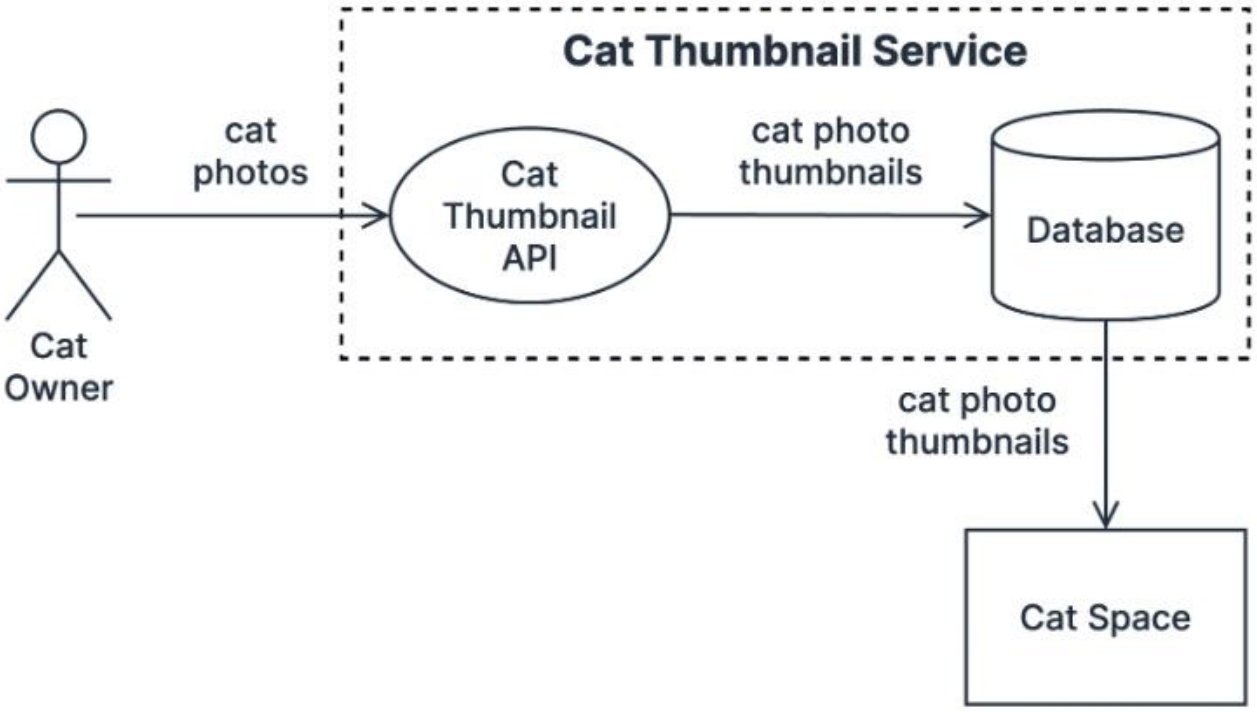
샘플 데이터 흐름



신뢰의 경계를 그리다

차량 등록 기능의 어떤 영역 또는 요소 그룹을 동등하게 신뢰할 수 있는지 파악하십시오. 이것이 바로 신뢰 영역입니다. 또한, 어떤 영역을 서로 또는 시스템의 나머지 부분과 다르게 신뢰해야 하는지 결정하십시오.

신뢰의 샘플 영역



Debrief: What Are We Working On?

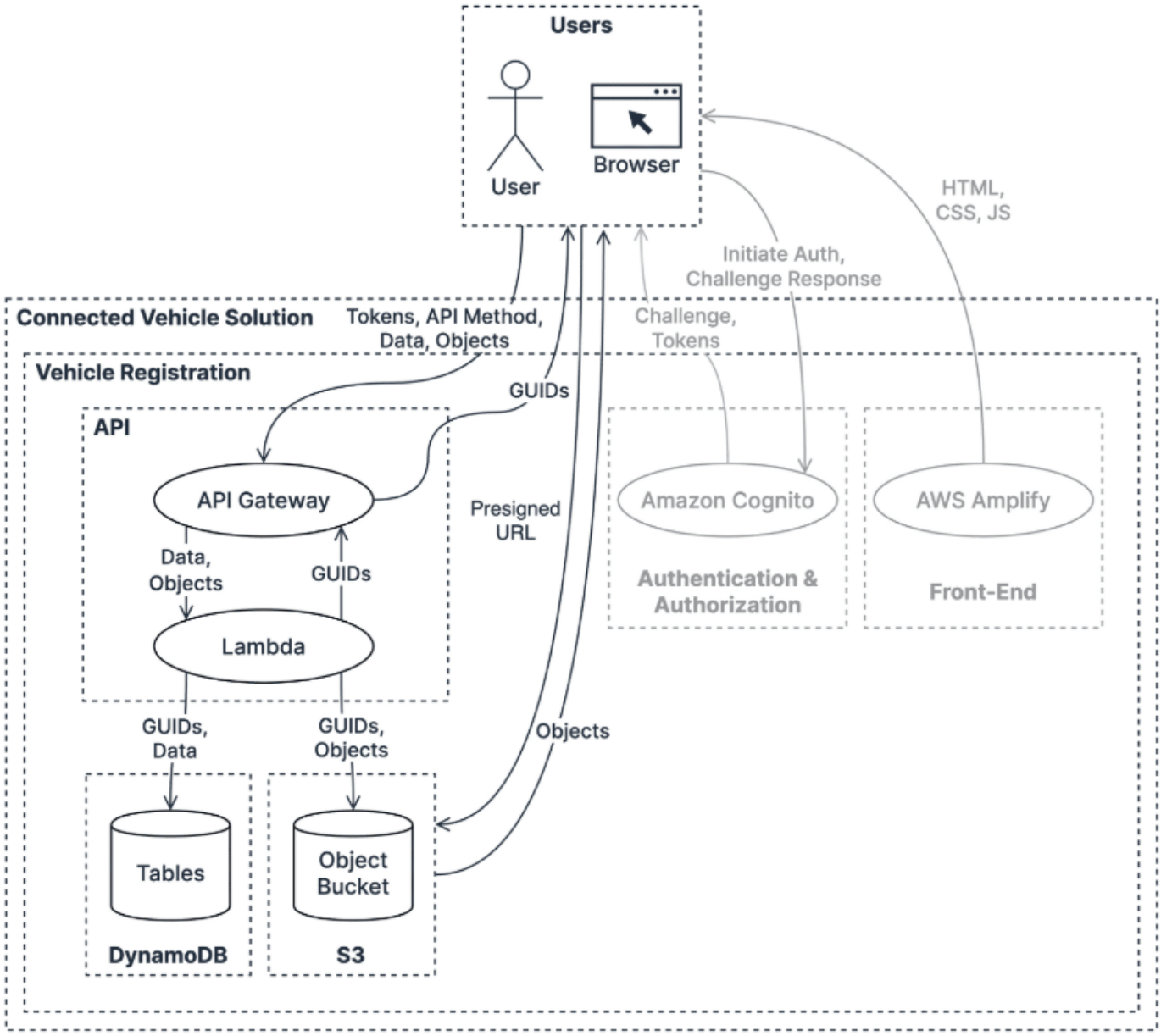
샘플 가정

다음은 이 연습과 관련된 가정의 예시 목록입니다. 이 목록은 완전하거나 권위 있는 목록은 아니지만, 비교에는 유용할 수 있습니다.

상표	설명
WWWO-Assume-1	REST 기반 API는 AWS Lambda와 Amazon API Gateway에서 제공됩니다.
WWWO-Assume-2	모든 사용자가 모든 작업을 수행할 수 있습니다.

참조 데이터 흐름도

다음 섹션에서 소개할 참조 데이터 흐름도는 다음과 같습니다. 비교에 활용해 보세요.



2. What Can Go Wrong?

무엇이 잘못될 수 있나요?

Lesson topics

1. Overview
2. STRIDE
3. STRIDE-per-element
4. Definition of done
5. Reference data flow diagram

개요

시스템에서 어떤 문제가 발생할 수 있는지 이해하면 다음과 같은 데 도움이 됩니다.

- 그러한 일이 발생할 확률을 줄이는 방법을 찾으십시오.
- 그런 일이 일어나면 그 영향을 최소화하세요.

STRIDE는 여섯 가지 위협 범주로 구성된 약어입니다. 유사한 위협들을 침해하는 보안 속성에 따라 그룹화합니다.

이는 엄격한 분류법이 아닌 위협에 대한 체계적인 사고방식으로 사용하는 것이 가장 좋습니다.



1. 스푸핑 - 진위성을 침해합니다.

- 스푸핑은 실제 자신이 아닌 다른 사람 또는 무언가인 척하는 것을 말합니다.
- 악의적인 행위자는 시스템에 이미 알려진 신원을 사칭하여 그 신뢰를 악용할 수 있습니다.
- 완화에는 인증이 포함됩니다.

2. 변조 - 무결성을 위반합니다.

- 변조는 데이터, 실행 코드, 구성 등 수정이 의도되지 않은 것을 수정하는 것을 말합니다.
- 정지 상태, 메모리 또는 전송 중인 데이터에 발생할 수 있습니다.
- 완화책으로는 생산 데이터에 대한 인간의 접근을 최소화하고 암호화 서명을 검증하는 것이 있습니다.

3. 부인 - 부인 불가를 위반합니다.

- 부인은 실제로 취한 조치에 대해 이의를 제기하는 것입니다.
- 그 반대로, 실제로 취하지 않은 행동을 주장하는 것도 포함될 수 있습니다.
- 완화책에는 수정이나 삭제가 불가능한 감사 로그 항목을 생성하는 것이 포함됩니다.

4. 정보공개 - 비밀유지 의무 위반

- 정보 공개는 접근해서는 안 될 정보를 얻는 것입니다.
- 완화책에는 최소 권한 액세스 제어 및 암호화가 포함됩니다.

5. 서비스 거부(DoS) - 가용성을 침해합니다.

- DoS는 합법적인 사용자가 시스템을 사용하는 것을 방해하거나 억제합니다.
- 여기에는 데이터 파괴나 네트워크 용량, CPU 사이클, 메모리, 디스크 공간 등의 유한한 리소스 소모가 포함될 수 있습니다.
- 시스템 가용성이나 성능에 영향을 미치는 것이 목적입니다.
- 완화책에는 제한, 리소스 할당량, 최소 권한 액세스 제어가 포함됩니다.

6. 권한 승격(EoP) - 권한 위반

- EoP는 기존 액세스를 사용하여 허용되어서는 안 되는 작업을 수행합니다.
- 혼란스러운 대리인 문제는 EoP의 한 예입니다. 이는 작업을 수행할 권한이 없는 개체가 더 높은 권한을 가진 개체에게 작업을 수행하도록 강요하는 경우입니다. 예를 들어, 사용자가 서비스를 속여 다른 사용자의 파일을 수정하도록 하는 경우가 있습니다.
- 완화 조치에는 액세스 제어와 권한 확인이 포함됩니다.

요소당 STRIDE 차트

다음 차트는 STRIDE가 각 요소에 어떻게 적용되는지 보여줍니다.

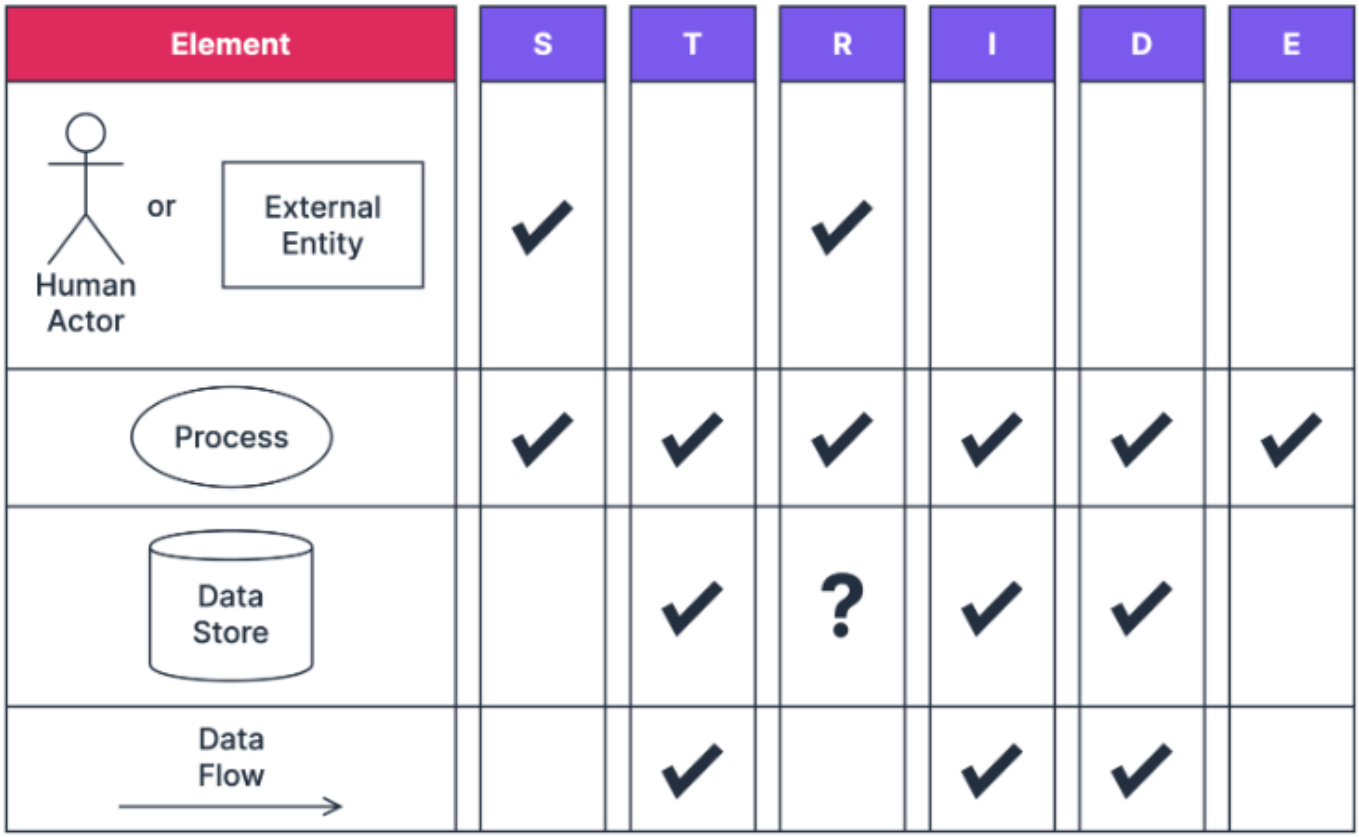


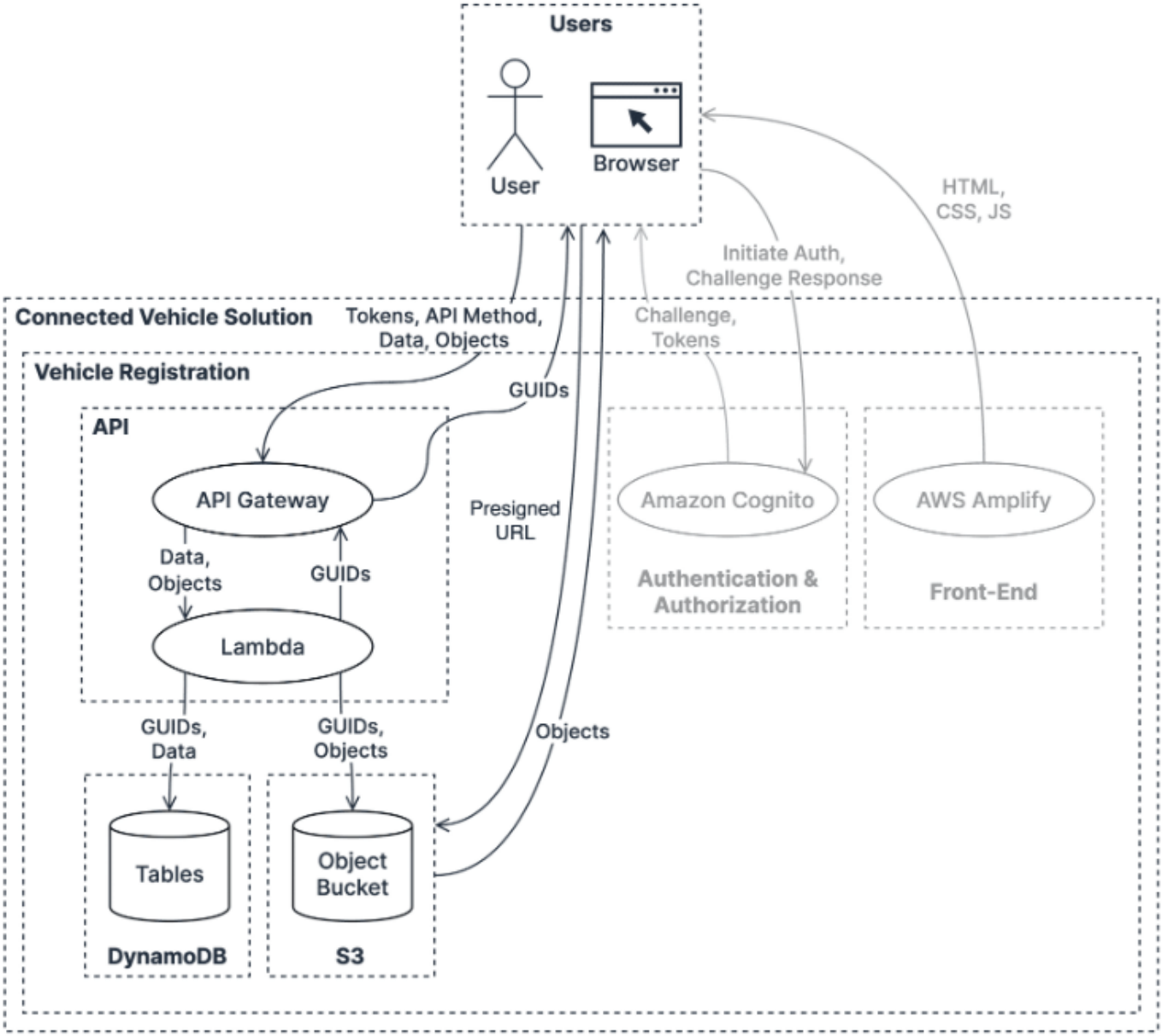
차트 특성

- 각 요소는 위협의 근원이라기보다는 위협의 표적이나 피해자입니다.
- 데이터 저장소는 일반적으로 부인될 수 있는 독립적인 작업을 수행할 수 없지만, 로깅 데이터 저장소는 이러한 공격의 특정 타깃이 될 수 있습니다.
- 거부 표시 아래의 "?"는 로그와 같은 일부 데이터 저장소에 거부 위협이 있을 수 있음을 나타냅니다.

참조 데이터 흐름도

강사 없이 이 과정을 완료하는 경우 이후 연습에서는 본인의 데이터 흐름 다이어그램을 사용해도 됩니다.

강사가 진행하는 과정의 경우, 아래에 표시된 참조 데이터 흐름도를 사용하세요. 이를 통해 강사가 위협 모델에 대해 더욱 적절한 지침을 제공할 수 있습니다.



완료의 정의

요소별 STRIDE를 사용할 때는 각 STRIDE 범주에서 요소별로 최소 하나의 위협을 파악해 보세요. 추가 위협을 파악할 수 없을 때까지 필요한 만큼 이 과정을 반복하세요.

더 나은 결과를 얻으려면 "무엇이 잘못될 수 있나요?"에서 완화책을 파악한 후 이 과정을 반복하세요. 이를 통해 완화책을 어떻게 우회하거나 위협할 수 있는지 고려할 수 있습니다.

분해

다이어그램을 여러 번 반복하고 더 깊이 파고드는 과정을 분해라고 합니다. 이는 더욱 완전한 위협 모델을 얻는 데 중요합니다.

완전성을 절대적으로 보장할 수는 없습니다. 분해는 추가적인 위협을 식별하는 훌륭한 방법이지만, 모든 위협을 찾아낼 수 있다는 보장은 없습니다.

Threat Grammar

LESSON 15 OF 27

Lesson topics

1. Basic threat grammar structure
2. Advanced threat grammar structure
3. Guidance
4. Decomposition
5. Identifying threats
6. Making it easier

기본 위협 문법 구조

일관되고 간결한 위협 진술을 작성하는 선호하는 방법이 없다면 다음 위협 문법 구조를 사용하는 것이 좋습니다.

[위협 소스] [전제 조건] 은 [위협 조치] **를 초래할 수 있으며** , 이는 [위협 영향] **으로 이어져** [영향을 받는 자산] 에 **부정적인 영향을 미칩니다 .**

각 위협 문법 필드의 정의와 예는 아래와 같습니다.

1. [위협 소스]

조치를 취하는 엔터티. 예:

- 위협 행위자(유용한 기본값).
- 인터넷 기반 위협 행위자.
- 내부 또는 외부 행위자.

2. [필수 조건]

위협 소스의 행동이 실행 가능하기 위해 충족해야 하는 조건 또는 요구 사항입니다. 예:

- 다른 사용자의 토큰에 접근할 수 있음.
- 관리자 접근 권한이 있는 사람.
- 사용자 권한이 있음.

전제 조건이 없다면 위협을 여러 개의 문장으로 분해해야 할 신호일 수 있습니다. 여기에는 동일한 위협 소스에 대한 여러 개의 전제 조건이 포함될 수 있습니다.

3. [위협 행위]

위협 소스가 수행하는 작업입니다. 예:

- 다른 사용자를 스푸핑합니다.
- 데이터베이스에 저장된 데이터를 변조합니다.
- 동시에 수천 개의 요청을 처리합니다.

4. [위협 영향]

성공적인 위협 행위의 직접적인 영향. 예를 들어:

- 사용자의 은행 계좌 정보에 대한 무단 액세스.
- 역대 최고 점수에 대한 사용자 이름 수정.
- 웹 애플리케이션이 다른 사용자 요청을 처리할 수 없습니다.

5. [영향을 받는 자산]

성공적인 위협 행위로 인해 영향을 받는 자산. 예:

- 사용자 뱅킹 데이터.
- 비디오 게임 최고 점수 목록.
- 웹 애플리케이션.

샘플 진술

- 다른 사용자의 토큰에 액세스할 수 있는 인터넷 기반 위협 행위자는 다른 사용자를 스푸핑하여 **사용자** 의 은행 계좌 정보를 볼 수 있게 하고 , **이는** 사용자 의 은행 데이터에 **부정적인 영향을 미칩니다** .

- 관리자 액세스 권한이 있는 내부 위협 행위자는 데이터베이스에 저장된 데이터를 변조 **할 수 있으며** , 이로 **인해** 역대 최고 점수에 대한 사용자 이름이 수정되어 비디오 게임 최고 점수 목록에 **부정적인 영향을 미칠 수 있습니다** .

- 사용자 권한이 있는 인터넷 기반 위협 행위자는 동시에 수천 개의 요청을 만들 **수 있으며** , **이로 인해** 애플리케이션이 다른 사용자 요청을 처리할 수 없게 되어 유효한 요청에 대한 웹 애플리케이션의 응답성에 **부정적인 영향을 미칩니다** .

Exercise: Find Threats

Lesson topics

1. Overview
2. Using STRIDE-per-element
3. State your assumptions
4. Threat composer tool
5. [S] Find spoofing threats to external entities
6. [T] Find tampering threats to data stores
7. [R] Find repudiation threats to external entities
8. [I] Find information disclosure threats to processes
9. [D] Find denial of service (DoS) threats to data stores
10. [E] Find elevation of privilege (EoP) threats to processes
11. Prioritize threats
12. Congratulations
13. Extra credit

차량 등록 기능 API

차량 등록 기능은 Amazon API Gateway에 구성되고 Lambda Functions에서 서비스되는 다음 API를 지원합니다.

차량 목록

사용 가능한 모든 IoT 연결 차량에 대한 정보를 반환합니다.

1. 매개변수는 입력으로 사용되지 않습니다.
2. 응답에는 `HTTP 응답 코드` , `vehicle_id` (문자열 - GUID), `vehicle_registered` (BOOLEAN)가 포함됩니다.

차량 등록

기존 IoT 연결 차량을 등록하여 서비스를 시작합니다.

1. `차량 ID` (문자열 - GUID), `차량 유형` (문자열), `차량` 등록 번호 (문자열) 및 차량 등록 문서의 PDF 버전(바이트)이 입력으로 사용됩니다.
2. 기존 DynamoDB 테이블 레코드가 `vehicle_type` 및 `vehicle_registration_number` 로 업데이트되었습니다 .
3. `vehicle_registered` 가 true로 설정되었습니다.
4. 접두사 /vehicle_registration_documents/<vehicle_id>.pdf 가 있는 차량 등록 문서(PDF)는 바이트 덩어리로 Amazon S3에 기록됩니다.
5. 응답에는 `HTTP 응답 코드` 와 차량 속성 (`vehicle_id` (GUID) 및 `vehicle_registered` (BOOLEAN) 포함)이 포함됩니다.

차량 등록 취소

기존에 등록된 IoT 연결 차량을 등록 해제하여 서비스를 중단합니다.

1. `vehicle_id` (STRING - GUID)가 입력으로 사용됩니다.
2. 기존 DynamoDB 테이블 레코드 필드인 `vehicle_type` 및 `vehicle_registration_number` 가 삭제되었습니다.
3. `vehicle_registered가` false로 설정되었습니다.
4. 접두사 /vehicle_registration_documents/<vehicle_id>.pdf 가 있는 차량 등록 문서(PDF)가 Amazon S3에서 삭제되었습니다.
5. 응답에는 `HTTP 응답 코드` 와 차량 속성 (`vehicle_id` (GUID) 및 `vehicle_registered` (BOOLEAN) 포함)이 포함됩니다.

차량 설명

사전 서명된 URL을 포함하여 특정 IoT 연결 차량에 대한 정보를 반환합니다.차량 등록 문서(등록된 경우):

1. vehicle_id (STRING - GUID)가 입력으로 사용됩니다.
2. 기존 DynamoDB 테이블 레코드가 쿼리되고, Lambda 함수 코드는 차량 등록 문서 Amazon S3 객체에 대한 미리 서명된 URL을 생성합니다.
3. 응답에는 HTTP 응답 코드 와 차량 속성이 포함됩니다. 여기에는 vehicle_id (GUID), vehicle_registered (BOOLEAN), vehicle_type (STRING), vehicle_registration_number (STRING), vehicle_registration_expiry_date (STRING), vehicle_registration_document_url (STRING)이 포함됩니다.

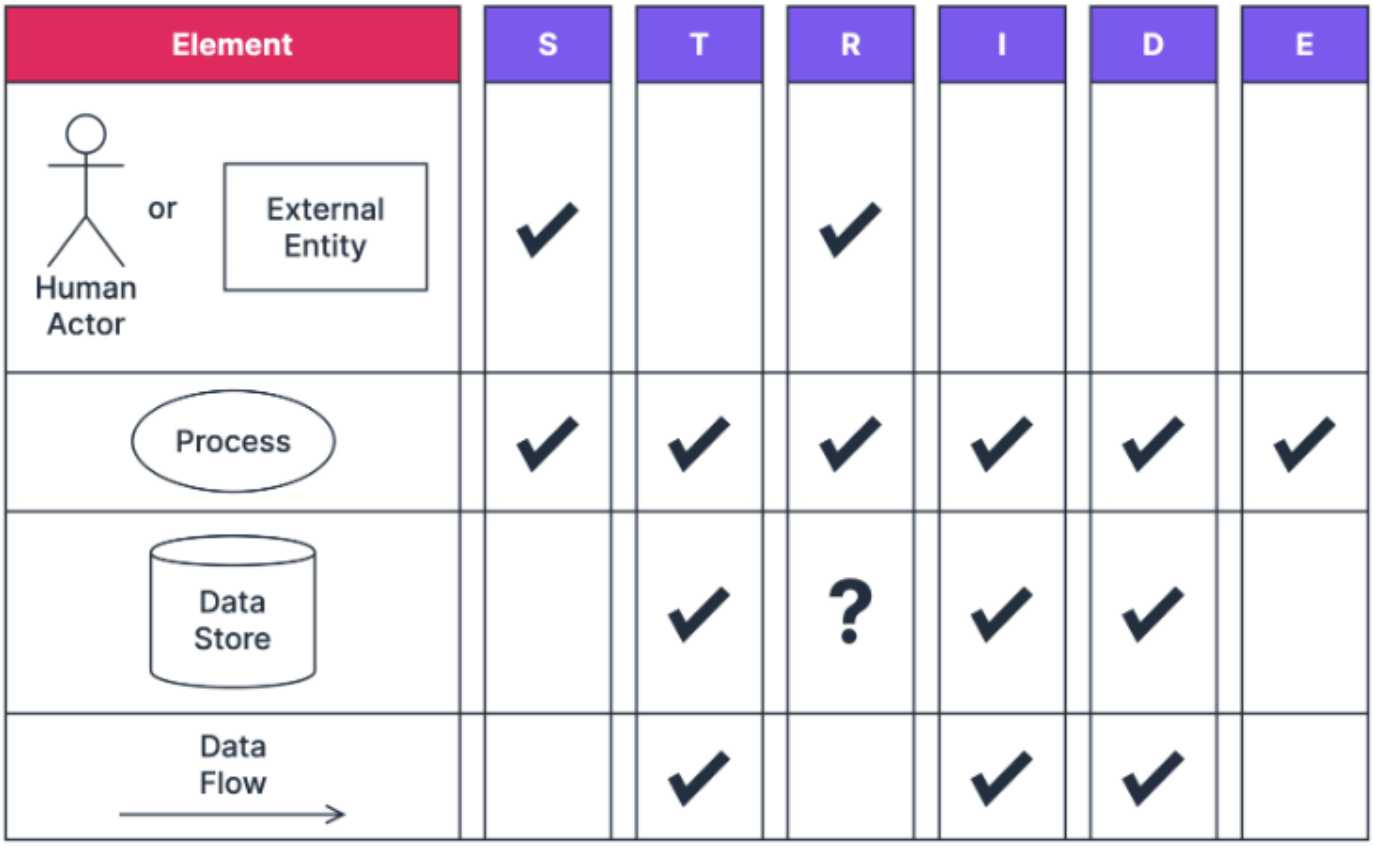
요소당 STRIDE 사용

아래 나열된 요소로 데이터 흐름 다이어그램을 채우면 해당 요소 간에 예상되는 데이터 흐름도 추가된다는 것을 의미합니다.

예상 요소와 데이터 흐름에 문제가 발생할 수 있는 부분을 파악하기 위해 요소당 STRIDE를 사용하는 것 외에도, 다음과 같은 다른 요소에 대한 **예상치 못한** 데이터 흐름과 위협을 파악하는 데도 요소당 STRIDE를 사용할 수 있습니다.

- 외부 엔터티,
- 프로세스 또는
- 데이터 저장소.

요소당 STRIDE 차트



당신의 가정을 말하세요

이전 연습에서와 마찬가지로 차량 등록 기능이 작동하는 방식에 대해 이미 가정을 했을 가능성이 있습니다.

가정을 나열하면 팀이 가장 관심 있는 분야에 집중하는 데 도움이 되므로 위협 모델링 프로세스에서 더 빨리 더 많은 가치를 얻을 수 있습니다.

5분 동안 여러분의 가정을 표로 정리하세요. 각 가정에 대한 라벨과 설명을 작성하세요. 라벨 접두사 WCGW는 Adam Shostack의 두 번째 질문인 "무엇이 잘못될 수 있을까?"를 줄인 것입니다.

상표	설명
WCGW-Assume-1	AWS 공유 보안 모델에서 우리 측의 위협에 집중하겠습니다.
WCGW-Assume-2	개별 AWS 서비스의 보안 기능과 구성 옵션을 신뢰할 수 있습니다.
...	...

위협 작성 도구

위협 작곡가이 도구는 위협 문법을 사용하여 위협 구문을 더 쉽게 작성할 수 있도록 설계되었습니다. 이를 통해 맞춤형 및 상황별 위협을 브레인스토밍하는 것이 더 쉬워집니다. 이 도구를 사용하여 여유 시간을 활용하여 유용한 위협을 반복적으로 작성해 보세요.

특징은 다음과 같습니다.

- 사용자 입력을 기반으로 구조화된 위협 진술을 제공합니다.
- 점점 더 완전한 사용자 입력을 지원하기 위한 적응형 위협 설명 구조입니다.
- 제공된 사용자 입력과 누락된 사용자 입력을 기반으로 한 동적 제안입니다.
- 문맥적 브레인스토밍과 재사용을 돕기 위한 완전한 위협 진술 예시입니다.
- 데이터는 브라우저 내 클라이언트 측에만 유지됩니다.
- 지속적인 저장 및 공유를 가능하게 하는 가져오기 및 내보내기 기능.
- 다양한 솔루션 요구 사항을 충족하기 위해 작업 공간을 분리했습니다.

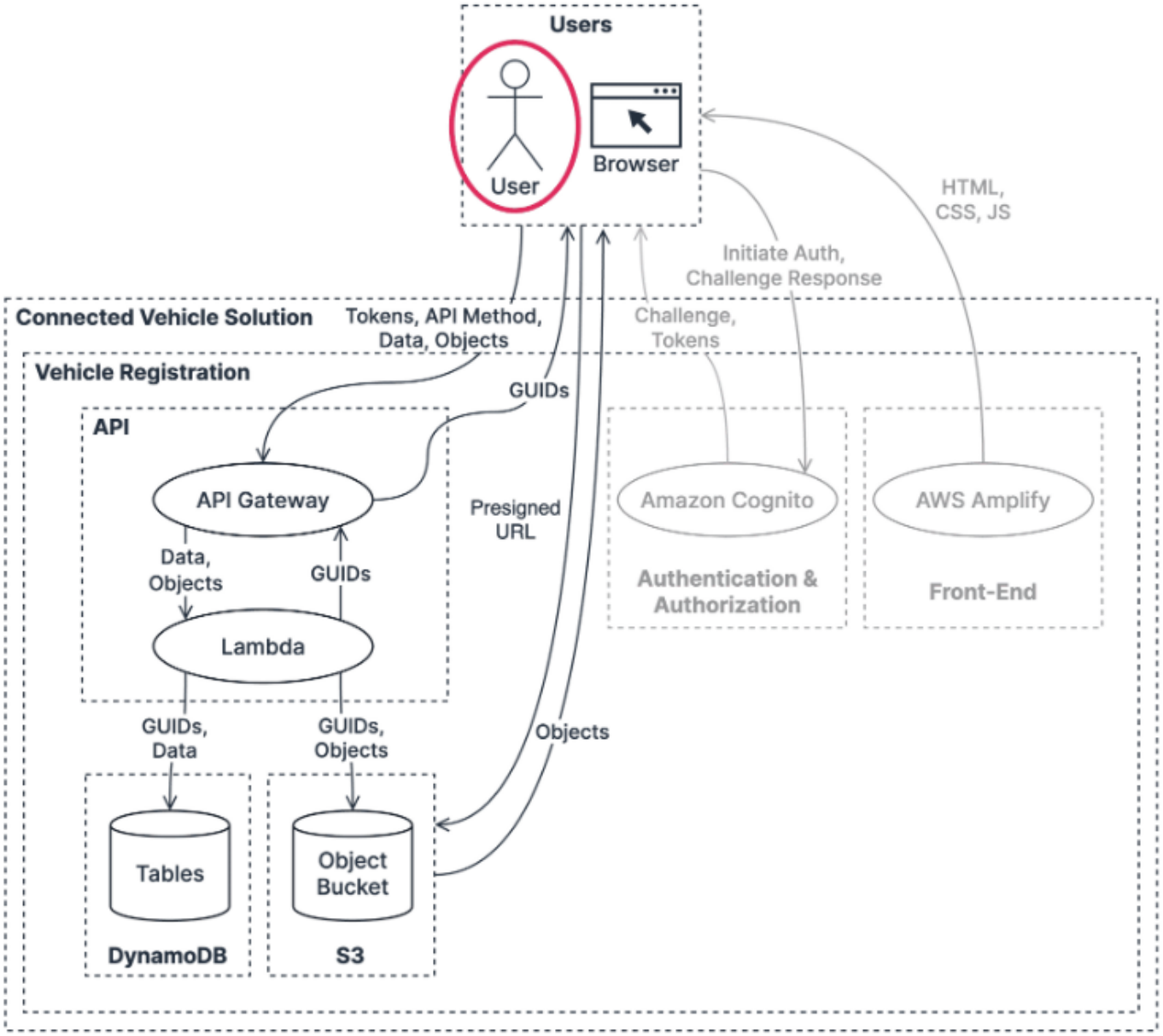
위협작성기 (https://github.com/awslabs/threat-composer)

https://awslabs.github.io/threat-composer/workspaces/default/dashboard

[S] 외부 기관에 대한 스푸핑 위협 찾기

STRIDE-per-element 차트를 보면 **스푸핑 위협이 외부 엔터티** 에 적용된다는 것을 알 수 있습니다 .

사용자 **는** 차량 등록 기능의 시스템 모델에 정의된 외부 엔터티입니다.



[위협 소스] [전제 조건] 은 [위협 조치] **를 초래할 수 있으며** , 이는 [위협 영향] **으로 이어져** [영향을 받는 자산] 에 **부정적인 영향을 미칩니다 .**

위협 ID, 요소 및 STRIDE 범주와 함께 위협 모델 테이블에 추가합니다.

위협 ID	위협 성명	요소	보폭
티01	[위협 소스] [전제 조건] 은 [위협 조치] **를 초래할 수 있으며** , 이는 [위협 영향] **으로 이어져** [영향을 받는 자산] 에 **부정적인 영향을 미칩니다 .**	사용자	에스

이러한 경우 요소가 어떻게 상호 작용하는지 알아보려면 차량 등록 기능에서 지원하는 각 작업(ListVehicles , RegisterVehicle , DeregisterVehicle , DescribeVehicle)에 대한 프로세스를 살펴보는 것이 유용할 수 있습니다 .

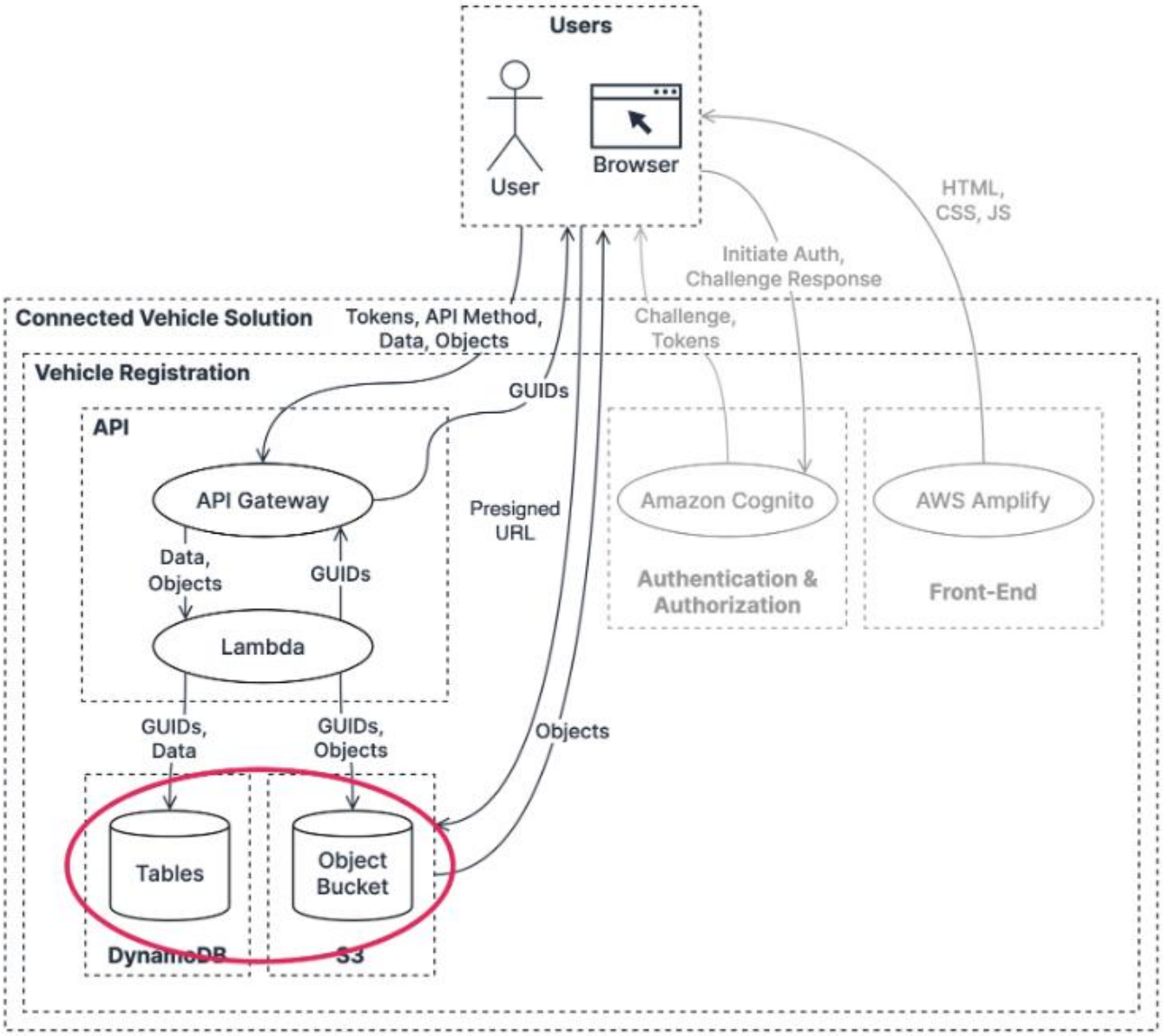
위협 작성기

https://awslabs.github.io/threat-composer/?mode=ThreatsOnly

[T] 데이터 저장소에 대한 변조 위협 찾기

STRIDE-per-element 차트를 보면 **변조 위협 이 데이터 저장소** 에 적용된다는 것을 알 수 있습니다 .

테이블 과 **객체 버킷은** 차량 등록 기능의 시스템 모델에 정의된 데이터 저장소입니다 **.**



저장 중인 데이터를 손상시키는 것은 가장 명확한 위협 중 하나입니다.

> ⓘ **예를 들어 : 위협 행위자가 개체 버킷의 개체를 수정할 수 있습니까?**

5분 동안 데이터 저장소당 하나의 변조 위협 진술문을 작성하세요. 위협 모델 테이블에 추가하세요.

위협 ID	위협 성명	요소	보폭
T02	[위협 소스] [전제 조건] 은 [위협 조치] **를 초래할 수 있으며** , 이는 [위협 영향] **으로 이어져** [영향을 받는 자산] 에 **부정적인 영향을 미칩니다 .**	테이블	티
T03	...	객체 버킷	티

힌트가 필요하신가요? 위협 작성기 내에서도구에서 '전체 예시'를 STRIDE = Tampering 으로 필터링합니다.

https://awslabs.github.io/threat-composer/?mode=ThreatsOnly

[R] 외부 엔터티에 대한 거부 위협 찾기

STRIDE-per-element 차트에서 **거부 위협은 외부 엔터티** 에 적용된다는 것을 알 수 있습니다 .

사용자 **는** 차량 등록 기능의 시스템 모델에 정의된 외부 엔터티입니다.

이번에는 외부 엔터티가 수행한 작업(예: 차량 등록)을 부인하거나 수행하지 않은 작업(예: 물건 보관)을 수행했다고 주장하는 방법에 대해 생각해 보세요.

5분 동안 부인 위협 진술문 하나를 작성하세요. 위협 모델 표에 추가하세요.

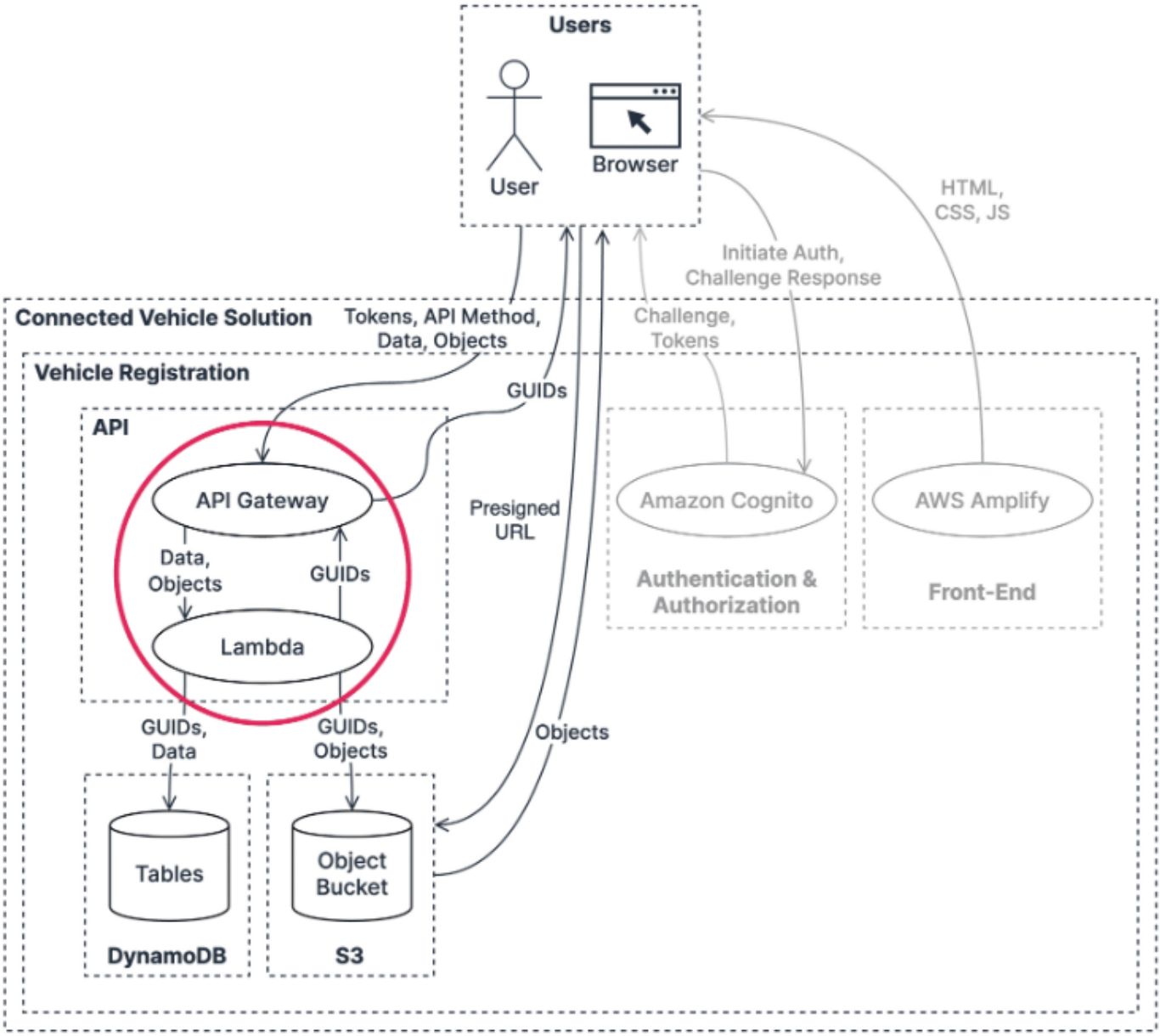
위협 ID	위협 성명	요소	보폭
티04	[위협 소스] [전제 조건] 은 [위협 조치] **를 초래할 수 있으며** , 이는 [위협 영향] **으로 이어져** [영향을 받는 자산] 에 **부정적인 영향을 미칩니다 .**	사용자	아르자형

힌트가 필요하신가요? 위협 작성기 내에서도구에서 '전체 예'를 STRIDE = Repudiation 으로 필터링합니다.

[I] 프로세스에 대한 정보 공개 위협을 찾습니다.

STRIDE-per-element 차트를 보면 **정보 공개 위협이 프로세스** 에 적용된다는 것을 알 수 있습니다 .

API **Gateway** 와 **Lambda는** 차량 등록 기능의 시스템 모델에 정의된 프로세스입니다.



프로세스는 데이터를 처리합니다. 정보 공개는 프로세스가 처리하는 데이터를 의도된 수신자만 읽을 수 있도록 보장하지 못할 때 발생합니다.

프로세스가 데이터를 오가며 처리할 수밖에 없는 상황에 놓일 수 있습니다. 또한, 개발 과정에서 발생하는 실수로 인해 프로세스가 데이터를 잘못 처리할 수도 있습니다.

> ⓘ **예를 들어 : Lambda 함수 내에서 실행되는 코드가 잘못된 S3 객체에 대한 참조를 반환할 수 있을까요?**

5분 동안 프로세스당 정보 유출 위협 진술문을 하나씩 작성하세요. 위협 모델 표에 추가하세요.

위협 ID	위협 성명	요소	보폭
티05	[위협 소스] [전제 조건] 은 [위협 조치] **로 이어져** [위협 영향]이 [영향을 받는 자산] 에 **부정적인 영향을 미칠 수 있습니다 .**	API 게이트웨이	나
티06	...	람다	나

[D] 데이터 저장소에 대한 서비스 거부(DoS) 위협 찾기

STRIDE-per-element 차트를 보면 **DoS 위협 이 데이터 저장소** 에 적용된다는 것을 알 수 있습니다 .

테이블 과 **객체 버킷은 차량 등록 기능 의** 시스템 모델에 정의된 데이터 저장소입니다.

데이터 저장소와 관련하여 DoS 위협은 어떤 방식으로든 데이터 접근을 거부할 가능성이 높습니다. 가장 일반적으로는 데이터 파괴 또는 접근 권한 취소가 포함됩니다.

> ⓘ **예를 들어 : 위협 행위자가 Amazon S3 버킷에서 객체를 삭제할 수 있을까요?**

위협 ID	위협 성명	요소	보폭
티07	[위협 소스] [전제 조건] 은 [위협 조치] **를 초래할 수 있으며** , 이는 [위협 영향] **으로 이어져** [영향을 받는 자산] 에 **부정적인 영향을 미칩니다 .**	테이블	디
티08	...	객체 버킷	디

힌트가 필요하신가요? 위협 작성기 내에서도구에서 '전체 예'를 STRIDE = 서비스 거부로 필터링합니다.

[E] 프로세스에 대한 권한 상승(EoP) 위협 찾기

STRIDE-per-element 차트를 보면 **EoP 위협이 프로세스** 에 적용된다는 것을 알 수 있습니다 .

API **게이트웨이** 와 **람다는** 차량 등록 기능의 시스템 모델에 정의된 프로세스입니다.

프로세스에서 EoP는 연결된 요소 중 하나가 예상보다 더 신뢰도가 높아지는 경우 발생합니다.

> ⓘ **예를 들어 : API 호출에 리소스를 수정하기 위한 권한 확인이 누락되어 사용자 및 관리자 신뢰 영역에서 작업이 허용되는가요?**

5분 동안 프로세스당 하나의 EoP 위협 선언문을 작성하세요. 위협 모델 표에 추가하세요.

위협 ID	위협 성명	요소	보폭
티09	[위협 소스] [전제 조건] 은 [위협 조치] **를 초래할 수 있으며** , 이는 [위협 영향] **으로 이어져** [영향을 받는 자산] 에 **부정적인 영향을 미칩니다 .**	API 게이트웨이	이자형
티10	...	람다	이자형

위협의 우선순위를 정하세요

잘못될 가능성이 있는 것들의 우선순위를 정하는 방법에는 여러 가지가 있습니다. 예를 들어, 영향 대비 완화 비용을 추정할 수 있습니다. 투자 수익률(ROI)이 가장 높은 것들을 먼저 우선순위에 둘 수 있습니다.

5분 동안 각 위협이 고객과 데이터에 미치는 위험 정도를 기준으로 위협의 우선순위를 높음, 보통, 낮음으로 정해 보세요. 이처럼 간단한 접근 방식은 최소한의 노력으로 빠르게 결과를 도출하며, 다음 연습에서 각 위협에 대한 대처 방안을 결정하는 데 도움이 될 것입니다.

우선 사항	위협 ID	위협 성명	요소	보폭
[H, M, 또는 L]	티01	[위협 소스] [전제 조건] 은 [위협 조치] **를 초래할 수 있으며** , 이는 [위협 영향] **으로 이어져** [영향을 받는 자산] 에 **부정적인 영향을 미칩니다 .**	사용자	에스

이때는 위협의 중복이나 허점을 검토하기에 좋은 시기입니다. 두 가지 위협 중 어느 것이 더 중요한지 판단하려면 다음과 같은 질문을 해 보세요. "두 가지 위협 중 하나에만 대응할 수 있고 다른 하나는 대응할 수 없다면, 어떤 위협을 먼저 해결해야 할까요?"

위협의 우선순위를 정하는 데 더 깊이 들어가려면 위험 기반 접근 방식을 취하는 것이 좋습니다. 위험은 위협 발생 가능성에 위협의 영향, 즉 이벤트의 비용을 곱한 값입니다. AWS는 고객 중심적인 접근 방식을 취하며 고객 신뢰를 훼손할 가능성이 가장 높은 위협의 우선순위를 정합니다.

위험 매트릭스

귀하의 회사에는 영향과 발생 가능성을 사용하여 높음, 중간, 낮음 위험을 구분하는 위험 매트릭스가 이미 있을 수 있습니다.

산업 중심 위험 매트릭스로 시작하려는 경우 OWASP는 위험 심각도 결정 에서 하나를 게시합니다.OWASP 위험 평가 방법론 섹션안내.

(https://owasp.org/www-community/OWASP_Risk_Rating_Methodology#step-4-determining-the-severity-of-the-risk)

Likelihood and Impact Levels	
0 to <3	LOW
3 to <6	MEDIUM
6 to 9	HIGH

'''Threat agent factors'''					'''Vulnerability factors'''			
Skill level	Motive	Opportunity	Size		Ease of discovery	Ease of exploit	Awareness	Intrusion detection
5	2	7	1		3	6	9	2
Overall likelihood=4.375 (MEDIUM)								

Technical Impact					**Business Impact**			
Loss of confidentiality	Loss of integrity	Loss of availability	Loss of accountability		Financial damage	Reputation damage	Non-compliance	Privacy violation
9	7	5	8		1	2	1	5
Overall technical impact=7.25 (HIGH)					Overall business impact=2.25 (LOW)			

3. What Are We Going to Do About it?

우리는 이에 대해 무엇을 할 것인가?

27개 중 19번째 수업

수업 주제

1. 개요
2. 위험 대응 전략
3. 모두 하나로 모으다

위험 대응 전략

이 연습을 시작하기에 앞서, 위협 발생 위험에 대처하기 위해 취할 수 있는 몇 가지 전략을 소개하고자 합니다. 위험에 대응하기 위해 사용할 수 있는 네 가지 일반적인 전략은 다음과 같습니다.

자세한 내용을 알아보려면 4개 탭을 각각 선택하세요.

피하다 | 완화시키다 | 옮기다 | 수용하다

- 위험은 기능 제공 중단을 결정하는 등 위험의 근원을 제거함으로써 피할 수 있습니다.
- 때로는 위험이 너무 커서 해당 활동을 전혀 하지 않는 것이 가장 현명한 대처 방법일 수 있습니다.

AVOID | MITIGATE | TRANSFER | ACCEPT

연습: 위험 대응 전략 선택

위험에 대해 어떻게 할 것인지 결정하세요

플랫폼에 내장된 보안 제어 기능을 활용하면 위협을 완화할 수 있는 경우가 많습니다. 예를 들어, 대부분의 AWS 서비스에는 Signature 버전 4가 필요합니다.클라이언트 상호 작용을 위한 (SigV4) 인증이며 모두 전송 계층 보안을 사용합니다.(TLS)를 기본적으로 사용하여 네트워크 통신을 보호합니다.

AWS Well-Architected 보안 기둥

AWS Well-Architected Security Pillar 에 설명된 설계 원칙 및 모범 사례에 맞춰 기능 및 서비스 설계워크로드에 특화된 위협에 위험 완화 리소스를 집중할 수 있습니다.

다음은 보안 기둥 내 각 영역에 맞춰 고려해야 할 표준 완화책에 대한 몇 가지 제안입니다.

- 보안 기반 - AWS 계정 관리 및 분리(AWS 조직))
- ID 및 액세스 관리 - 인증(AWS IAM), 권한 부여(AWS IAM ID 정책, 리소스 정책)
- 발각 - 가시성/감사 (Amazon CloudWatch Logs), AWS 클라우드 트레일), 보안 구성(AWS Security Hub), AWS Config 규칙), 위협 탐지(Amazon GuardDuty)
- 인프라 보호 - 네트워크 분리 및 필터링(Amazon VPC), 서브넷, 보안 그룹), 입력 검증(API Gateway 요청 검증)), 출력 이스케이프(HTML, XML, JSON 등에 대한 표준 인코딩 라이브러리 사용)
- 데이터 보호 - 전송 중인 데이터의 암호화, 서명 및 인증(TLS); 저장 중인 데이터의 암호화(KMS), AWS 암호화 SDK)

AWS 보안 문서

또한, 전담 보안 챕터각 AWS 서비스의 보안 구성은 해당 서비스에서 제공하는 적절한 보안 구성을 선택하는 데 도움이 될 수 있습니다. Amazon S3 와 같은 데이터 흐름 다이어그램의 프로세스에 대한 보안 관련 장을 살펴보세요.그리고 DynamoDB예방적 조치와 탐지적 조치를 모두 고려하는 것을 잊지 마세요.

OWASP 지침 참조

AWS 서비스 구성과 관련되지 않은 완화책(특히 Lambda 함수 내에서 실행되는 코드와 관련된 완화책)의 경우 OWASP 에서 권장하는 일반적인 완화책 전략을 고려하십시오.예를 들어, 주입 위협에 대한 특정 완화책의 경우 OWASP 웹사이트에 나열된 완화책을 고려할 수 있습니다..

AWS Security Documentation(https://docs.aws.amazon.com/security/)

Exercise guidance

모든 위협에는 악용될 위험이 따릅니다. 환경에서 제공하는 표준 완화 전략을 적용하여 완화되지 않은 각 위협에 대해, 해당 위험을 해결하는 데 적합한 다른 완화 전략을 결정해야 합니다.

AWS 커넥티드 카 솔루션을 제공하는 데 전념하고 있기 때문에 위험을 피할 수 없습니다. Amazon API Gateway, AWS Lambda, Amazon S3, Amazon DynamoDB를 직접 구축하는 대신, AWS로 최대한 많은 위험을 이전했습니다. 남은 선택지는 위험을 완화하거나, 위험을 감수하거나, 아니면 두 가지를 병행하는 것입니다.

위험 수용보다는 모든 위험을 완화하는 것이 더 바람직한 접근 방식입니다. 그러나 비용이나 복잡성으로 인해 위험을 합리적으로 완화할 수 없다면, 위험을 수용하는 것이 유일한 선택지입니다. 위험을 수용할 때는 제한된 기간 동안만 허용해야 합니다. 이 기간은 엔지니어들이 적절한 완화 방안을 연구하고 구현할 수 있도록 하기 위한 것입니다. 위험의 규모와 관계없이 위험을 수용할 때는 반드시 리더십과 소통해야 합니다.

차량 등록 기능 설계자로서, 위협 발생 가능성이나 영향을 줄일 수 있는 방법을 생각해 보세요. 지금이 바로 창의력을 발휘할 기회입니다! 관련 위협 발생 위험을 줄이는 데 도움이 된다면, 정답은 얼마든지 있습니다.

특정 완화책을 선택하고 다른 완화책을 폐기한 이유를 기록해 두면 향후 위협 모델을 다시 검토할 때 더 수월해집니다. 예를 들어, 특정 위협에 대해 완화책 C 대신 A와 B를 선택한 이유를 기록해 두면 나중에 그 선택을 한 이유를 이해하는 데 도움이 됩니다.

Exercise steps

1. 위협 모델 표에서(또는 아래의 예시를 활용하여) 위협 목록을 검토하고 하나 이상의 표준 완화책을 적용하여 완화할 수 있는 위협을 파악합니다.

2. 해당 위험을 완화된 것으로 표시하고 잠재적 완화 조치 및 선택된 완화 조치 상자를 사용하여 표준 완화 조치가 어떻게 위험을 줄이는지 설명합니다.

3. 남아 있는 위협 각각에 대해 잠재적 완화 방안 상자에 해당 위협이 발생할 위험을 줄일 수 있는 방법을 최대한 많이 적어 두십시오.

4. 그런 다음 허용 가능한 비용(시간/노력)으로 위험을 허용 가능한 수준으로 줄일 수 있는 완화책의 조합을 결정하고 선택한 완화책 상자에 결정 이유와 함께 이를 기록합니다.

우선 사항	위협 ID	위협 성명	요소	보폭	잠재적 완화책	선택된 완화책
	티01	유사한 도메인 이름을 소유한 위협 행위자는 사용자를 속여 가짜 엔드포인트와 상호 작용하게 **할 수 있으며** , **이로 인해** 유효한 API 요청이 가로채지고 차량 등록 , 차량 목록, 등록 상태 및 차량 등록 문서에 **부정적인 영향을** 미칩니다 .	사용자	에스		
	T02	DynamoDB 테이블에 액세스할 수 있는 위협 행위자는 중요한 데이터에 액세스 **할 수 있으며** , 그 결과 차량 등록, 차량 목록 및 등록 상태 **의** 기밀성이 **낮아집니다** .	테이블	티		
	T03	사용자와 Amazon S3 버킷 간에 전송되는 데이터에 액세스할 수 있는 위협 행위자는 해당 데이터를 읽거나 수정할 **수 있으며** , **그 결과** 차량 등록 문서 **의** 기밀성 및/또는 무결성이 감소합니다 .	객체 버킷	티		

	티04	차량을 등록할 수 있는 위협 행위자가 등록하지 않았다고 주장 **할 수** 있으며 , **이로 인해** 행위자가 차량 등록과 관련된 재정적 비용에 대해 이의를 제기하게 되고 , **결과적으로** 청구의 무결성이 저하됩니다 .	사용자	아르 자형		
	티05	인증을 받고 API 요청을 할 수 있는 위협 행위자는 읽을 권한이 없는 정보를 읽을 **수 있으며** , **그로 인해** 차량 등록, 차량 목록, 등록 상태 및 차량 등록 문서 **의** 기밀성이 낮아집니다 .	API 게이트웨이	나		
	티06	AWS Lambda 함수 로그에 액세스할 수 있는 위협 행위자는 로그에 캡처된 중요한 데이터를 찾을 **수** 있으며 , 그 결과 차량 등록, 차량 목록, 등록 상태 및 차량 등록 문서 **의** 기밀성이 **낮아질 수 있습니다** .	람다	나		
	티07	DynamoDB 테이블에 대한 수정 권한이 있는 IAM 주체에 대한 액세스 권한이 있는 위협 행위자는 데이터를 삭제할 **수 있으며** , **그로 인해** 차량 등록, 차량 목록 및 등록 상태 **의** 가용성이 감소합니다 .	테이블	디		
	티08	S3 버킷에 대한 수정 액세스 권한이 있는 IAM 주체에 액세스할 수 있는 위협 행위자는 Amazon S3 버킷의 데이터가 삭제되도록 **할 수** 있으며 , 그 결과 차량 등록 문서 **의** 가용성이 **감소합니다** .	객체 버킷	디		

	티09	중간자적 위치에 있는 위협 행위자 는 API 매개변수 입력을 조작하여 **API Gateway** 가 다른 사용자의 리소스에 대한 작업을 수행하게 할 수 있으며 , **그 결과** 차량 등록, 차량 목록, 등록 상태 및 차량 등록 문서 **의** 무결성과 기밀성이 저하됩니다 .	API 게이트웨이	이자형		
	티10	위협 행위자는 권한 부여 논리의 오류를 이용하여 **권한** 이 없는 작업을 수행할 수 있는 권한을 **갖게 되고, 이는** 차량 등록 , 차량 목록, 등록 상태 및 차량 등록 문서에 **부정적인 영향을 미칩니다** .	람다	이자형		

문맥

아래 위협 및 완화 조치 표는 예시입니다. 이 표는 연습 과정에서 수행한 작업에 대한 참고 자료를 제공하기 위한 것입니다. 저희는 위협 문법을 사용했지만, 꼭 그럴 필요는 없습니다.

이 표는 저자들이 정해진 기간 내에 작업한 결과입니다. 저희는 이 작업이 가상 기능의 설계 초기 단계라고 생각했습니다. 설계가 더욱 세부화됨에 따라 더 많은 위협이 식별될 것이며, 아래 위협 중 다수는 여러 개의 더욱 세부적인 위협으로 분해될 수 있습니다. 마찬가지로, 이 완화 조치 예시는 높은 수준의 내용이며, 워크로드에 대한 완화 조치를 구현할 때 활용해야 할 유용한 지침을 제공합니다. 설계가 발전함에 따라 더욱 세부적인 완화 조치를 수립해야 합니다.

이러한 완화 조치만으로는 위험을 허용 가능한 수준으로 줄일 수 있다는 것을 의미하지 않습니다. 대부분의 조직은 완화 비용과 예상 위험 비용을 비교합니다. 대부분의 사람과 조직은 10달러의 자산을 보호하기 위해 100달러를 지출하지 않을 것입니다.

샘플 완화책 및 샘플 위협 모델 표

아래 두 표를 참조하세요. "위험 대응 전략 선택" 연습에서 나온 완화 방안 예시 목록과 완화 방안이 적용된 위협 샘플 표입니다.

완화 조치 목록은 완전하거나 권위 있는 것은 아니지만, 비교에 유용할 수 있습니다. 위협과 완화 조치를 매핑했으며, 반대로 완화 조치와 위협을 매핑했습니다. 예시 목록에 있는 모든 완화 조치가 연관된 위협을 가지고 있는 것은 아닙니다. 이전 연습이나 선택 과목인 '추가 점수'에서 다른 위협을 발견한 경우, 해당 완화 조치가 적용될 수 있습니다. 필요한 경우 Threat Composer 도구를 사용하여 추가 사항을 추가하여 위협 표를 완성하십시오.

앞서 위험은 회피, 완화, 이전 또는 수용될 수 있다는 점을 논의했습니다. 아래에서는 완화 조치에 대한 참조만 볼 수 있습니다. 위험을 **회피** 하거나 **이전했다면** 설계를 변경한 것이며, 관련 위협과 완화 조치를 포함할 필요가 없습니다. 예를 들어, 워크로드 구축을 피했다면 모델링할 시스템이 없습니다. 직접 소유하고 운영하는 하드웨어에서 코드를 실행하는 대신 AWS Lambda를 선택하여 위험을 일부 이전했다면 물리적 서버, 운영 체제, 가용성, 로깅 등과 관련된 여러 위협을 피할 수 있었습니다. Lambda에서 코드를 실행하는 것과 관련된 위협은 여전히 존재하지만, 걱정할 부분이 훨씬 줄어듭니다.

아래에 이에 대한 예는 없지만, 위험을 **수용하기** 로 결정했다면 위협 모델에 해당 위험을 문서화하고, 조직의 위험 수용에 대한 기존 프로세스를 따라야 합니다.

완화 번호	완화	위협 완화
엠-001	전송 중인 데이터 보호	T01, T03, T09
엠-002	API Gateway API 응답 구성 적절한 정보만 반환	티05
엠-003	Amazon CloudWatch Logs로 민감한 데이터 보호	티06
엠-004	AWS 모니터링 및 로깅 사용	티04
엠-005	모든 입력 검증: "입력 검증은 올바르게 형식이 지정된 데이터만 소프트웨어 시스템 구성 요소에 입력되도록 보장하는 프로그래밍 기술입니다."	T05, T09
엠-006	AWS Certificate Manager(ACM)를 사용하여 공개 및 비공개 SSL/TLS 인증서를 프로비저닝, 관리 및 배포합니다.	티01
엠-007	중요 리소스에 대한 액세스 관리최소 권한 권한을 적용합니다 .	T02, T07, T08
엠-008	저장된 데이터를 보호하세요	T07, T08
엠-009	데이터를 백업하세요	T07, T08
엠-010	보안 제어의 테스트 및 검증을 자동화합니다.	T09, T10
엠-011	Cognito와 API Gateway를 사용하여 사용자 권한을 부여합니다.	T05, T09, T10

엠-012	IAM 보안 모범 사례 사용AWS 계정 및 리소스에 대한 액세스를 관리하려면	T02, T06, T07, T08
엠-013	미리 서명된 S3 URL 기능 제한	T03
엠-014	Cognito를 사용하여 사용자를 인증하세요	티09
엠-015	강력한 로그인 메커니즘을 사용하세요	티09
엠-016	Amazon Macie를 사용하여 민감한 데이터를 검색하고 보호하세요.	
엠-017	AWS 웹 애플리케이션 방화벽과 AWS Shield를 사용하세요	
엠-018	예상치 못한 또는 원치 않는 구성 변경을 감지하고 예상치 못한 동작을 감지합니다.	
엠-019	API Gateway에서 Lambda 통합 설정	
엠-020	API 요청 제한	
엠-021	탐지 제어 기능을 사용하여 잠재적인 보안 위협이나 사고를 파악합니다.	
엠-022	취약성 관리 수행	
엠-023	비용을 사전에 모니터링하세요	

이 위협 모델 표는 연습에서 수행한 작업에 대한 참고 자료를 제공합니다. 위협 및 완화 조치 목록은 상황에 따라 다를 수 있습니다.

우선 사항	위협 ID	위협 성명	요소	보폭	잠재적 완화책	선택된 완화책
	티01	유사한 도메인 이름을 소유한 위협 행위자는 사용자를 속여 가짜 엔드포인트와 상호 작용하게 **할 수 있으며** , **이로 인해** 유효한 API 요청이 가로채지고 차량 등록 , 차량 목록, 등록 상태 및 차량 등록 문서에 **부정적인 영향을** 미칩니다 .	사용자	에스		M-001, M-006
	T02	DynamoDB 테이블에 액세스할 수 있는 위협 행위자는 중요한 데이터에 액세스 **할 수 있으며** , 그 결과 차량 등록, 차량 목록 및 등록 상태 **의** 기밀성이 **낮아집니다** .	테이블	티		M-007, M-012
	T03	사용자와 Amazon S3 버킷 간에 전송되는 데이터에 액세스할 수 있는 위협 행위자는 해당 데이터를 읽거나 수정할 **수 있으며** , **그 결과** 차량 등록 문서 **의** 기밀성 및/또는 무결성이 감소합니다 .	객체 버킷	티		M-001, M-013

	티04	차량을 등록할 수 있는 위협 행위자가 등록하지 않았다고 주장 **할 수** 있으며 , **이로 인해** 행위자가 차량 등록과 관련된 재정적 비용에 대해 이의를 제기하게 되고 , **결과적으로** 청구의 무결성이 저하됩니다 .	사용자	아르 자형		엠-004
	티05	인증을 받고 API 요청을 할 수 있는 위협 행위자는 읽을 권한이 없는 정보를 읽을 **수 있으며** , **그로 인해** 차량 등록, 차량 목록, 등록 상태 및 차량 등록 문서 **의** 기밀성이 낮아집니다 .	API 게이트웨이	나		M-002, M-005, M-011
	티06	AWS Lambda 함수 로그에 액세스할 수 있는 위협 행위자는 로그에 캡처된 중요한 데이터를 찾을 **수** 있으며 , 그 결과 차량 등록, 차량 목록, 등록 상태 및 차량 등록 문서 **의** 기밀성이 **낮아질 수 있습니다** .	람다	나		M-003, M-012
	티07	DynamoDB 테이블에 대한 수정 권한이 있는 IAM 주체에 대한 액세스 권한이 있는 위협 행위자는 데이터를 삭제할 **수 있으며** , **그로 인해** 차량 등록, 차량 목록 및 등록 상태 **의** 가용성이 감소합니다 .	테이블	디		M-007, M-008, M-009, M-012
	티08	S3 버킷에 대한 수정 액세스 권한이 있는 IAM 주체에 액세스할 수 있는 위협 행위자는 Amazon S3 버킷의 데이터가 삭제되도록 **할 수** 있으며 , 그 결과 차량 등록 문서 **의** 가용성이 **감소합니다** .	객체 버킷	디		M-007, M-008, M-009, M-012

	티09	중간자적 위치에 있는 위협 행위자 는 API 매개변수 입력을 조작하여 **API Gateway** 가 다른 사용자의 리소스에 대한 작업을 수행하게 할 수 있으며 , **그 결과** 차량 등록, 차량 목록, 등록 상태 및 차량 등록 문서 **의** 무결성과 기밀성이 저하됩니다 .	API 게이트웨이	이자형		M-001, M-005, M-010, M-011, M-014, M-015
	티10	위협 행위자는 권한 부여 논리의 오류를 이용하여 **권한** 이 없는 작업을 수행할 수 있는 권한을 **갖게 되고, 이는** 차량 등록 , 차량 목록, 등록 상태 및 차량 등록 문서에 **부정적인 영향을 미칩니다** .	람다	이자형		M-005, M-010, M-011

4. Did We Do a Good Enough Job?

우리가 충분히 잘 했는가?

Lesson topics

1. Is our threat model useful?
2. Can we do a better job over time?

우리의 위협 모델이 유용한가?

위협 모델은 살아있는 문서처럼 취급해야 합니다. 모델링한 시스템을 폐기하기 전까지는 위협 모델 작업이 완료되지 않습니다. 따라서 충분히 잘 했는지 판단하기 어려울 수 있습니다. **위협 모델링을 하는 이유는 시스템의 보안을 강화하여 시스템을 개선하기 위해서입니다.** 위협 모델을 평가하려면 "무엇을 하고 있는가?", "무엇이 잘못될 수 있는가?", 그리고 "그에 대해 무엇을 할 것인가?"라는 질문에 충분히 답할 수 있는지 자문해 보세요.

시스템 수명 주기 전반에 걸쳐 위협 모델을 지속적으로 작성하는 것이 좋습니다. 구축하는 시스템의 세부 사항이 더욱 명확해지고 시스템이 더욱 복잡해질수록 시간이 지남에 따라 위협 모델이 더욱 세부적으로 표현되는 것을 발견하게 될 것입니다. 유용한 경험 법칙은 위협 모델이 다른 설계 문서만큼 상세해야 한다는 것입니다. 냅킨 뒷면에 아이디어가 있다면, 반대쪽 면을 위협 모델로 활용하세요! 상세한 설계 사양을 갖춘 견고한 운영 시스템을 사용하는 경우, 위협 모델도 동일한 수준의 세부 정보를 포함해야 합니다. 설계 문서를 직접 작성하지 않는 경우, 위협 모델링을 강제 기능으로 활용하고 위협 모델을 시스템 설계의 핵심 요소로 삼으세요.

시간이 지나면서 더 나은 성과를 낼 수 있을까?

이 워크숍에서는 시간 경과에 따른 개선 사항을 측정하는 것은 현실적으로 불가능하지만, 팀과 조직 전체의 위협 모델링 상태를 개선하기 위해 취할 수 있는 몇 가지 조치를 제안합니다.

Practice

- 여기서 배운 내용을 다른 업무나 개인 생활에 적용해 보세요.
- 위협 모델에 대한 기회를 파악하세요. 예를 들어, 형제 팀이 시작할 수 있도록 돕거나 위협 모델을 개선할 수 있습니다.
- 시퀀스 다이어그램이나 상태 전환 다이어그램과 같은 시스템 모델링을 위한 다른 기술을 살펴보세요.
- 기술 시스템 너머로 위협 모델링을 확장하세요. 비즈니스 프로세스나 개인 정보 보호 및 규정 준수 위험 등에 대한 위협 모델링을 고려해 보세요.

Learn

- 위협 모델링에 접근하는 방법을 읽어보세요. AWS 보안 블로그 의 블로그 게시물 .
- 보안 솔루션 에 대해 알아보세요 및 기능 AWS에서 사용 가능합니다. AWS 환경에서 제공하는 보안 솔루션을 이해하면 잠재적으로 비용/복잡성을 낮추면서 완화책을 더 빨리 파악할 수 있습니다.
- 다른 위협 모델링 방법론 탐색.

https://aws.amazon.com/ko/blogs/security/

Teach +

- 자신의 팀이나 형제팀을 대상으로 위협 모델링 연습을 주도합니다.
- 다른 사람들에게도 이와 같은 위협 모델 교육을 받도록 권장하세요!

Review −

- 팀 및 조직 내 다른 팀들과 함께 위협 모델을 주기적으로 검토하십시오. 다른 개발자에게 위협 모델의 정확성, 완전성, 그리고 명확성에 대한 피드백을 제공하는 것은 안전한 워크로드를 구축하는 데 중요한 부분입니다.
- 처음에는 알아차리지 못했던 추가적인 위협이 생길 수도 있습니다.
- 더욱 심층적인 방어를 제공하거나 운영 비용을 낮출 수 있는 개선된 완화 접근 방식이 있을 수 있습니다.

연습: 프로세스의 유용성 평가

1 **우리는 무엇을 작업하고 있는지 알고 있었나요?**

- 첫 번째 연습인 "우리는 무엇을 하고 있나요?"에서 만족스러운 차량 등록 기능 모델을 만들 수 있었나요?
- 적절한 도구(다이어그래밍 도구, 화이트보드 등)를 갖추고 있었나요?

2 **무슨 일이 잘못될 수 있는지 알고 있나요?**

- 두 번째 연습인 "무엇이 잘못될 수 있을까?"에서는 몇 가지 위협을 찾을 수 있었나요?
- 발견하신 위협의 수가 예상과 일치했나요? 예상보다 더 많은 위협을 발견하셨나요? 예상과 같은 위협을 발견하셨나요? 아니면 더 적은 위협을 발견하셨나요?

3 **우리는 이 문제에 대해 뭔가 조치를 취했나요?**

- 세 번째 연습인 "이 문제에 대해 우리는 무엇을 할 것인가?"에서 대략 몇 개의 완화책을 찾아내셨나요?
- 귀하가 취한 완화 조치가 발견된 위협을 적절히 완화했다고 생각하십니까?

4 **우리는 잘 실행했나요?**

- 이 과정이 유용하다고 생각하시나요?
- 위협 모델링 프로세스를 통해 차량 등록 기능을 설계하는 방식이 개선될 것이라고 생각하시나요?
- 이 워크숍을 마친 후, 귀하가 구축하고 있는 솔루션에 대한 위협 모델링을 귀하의 팀과 함께 시작할 수 있다고 생각하십니까?
- 아직 혼자서 위협 모델링을 시작할 수 없다고 생각된다면, 어떤 추가 지원이 그 단계에 도달하는 데 도움이 될까요? 예를 들어, 위협 모델링 경험이 있는 다른 엔지니어들과 매주 위협 모델링 진단 회의를 하거나, 도움을 요청할 수 있는 소통 채널을 이용하는 것이 좋습니다.